

CHAPTER 1

INTRODUCTION

1.1. Need for the Study/Technology

In today's digital-first healthcare environment, maintaining a balance between user experience and regulatory compliance is not just a technical goal—it is a critical necessity. Patients increasingly rely on mobile devices to access healthcare portals, schedule appointments, and view personal medical records. However, many healthcare platforms still suffer from poor mobile responsiveness, clunky navigation, and unintuitive designs that hinder user engagement and accessibility.

Simultaneously, the healthcare industry is a top target for cyberattacks due to the sensitive nature of patient data. HIPAA (Health Insurance Portability and Accountability Act) mandates specific privacy and security rules to protect this data, but non-compliance is still rampant. Several real-world data breaches highlight this issue. For instance, the 2015 Anthem Inc. breach compromised over 78 million records due to lack of adequate access control and audit systems. In another case, Blackbaud's 2020 ransomware incident exposed data from numerous healthcare institutions, resulting in legal consequences and regulatory investigations. In 2023, the HCA Healthcare breach exposed data of over 11 million individuals due to a misconfigured database, again pointing to a lack of automated compliance validation mechanisms.

Such incidents not only lead to massive financial penalties (Anthem paid \$16 million in settlement with the U.S. Department of Health and Human Services) but also erode public trust. The absence of tools that can automatically monitor, analyze, and ensure compliance with HIPAA privacy standards puts organizations at risk. Therefore, this project addresses the urgent need to create a system that not only enhances web usability but also ensures regulatory alignment through a HIPAA Compliance Checklist Tool.

1.2. Applications

- **For Seedatamd/Dotzza:** A polished, bug-free website directly improves user acquisition and retention. The HIPAA tool can be offered as a value-added service to its healthcare clients, solidifying its position as a trusted partner.
- **For Healthcare Startups:** A new telehealth platform can use the HIPAA tool to quickly audit their privacy policy during development, saving thousands in initial legal fees.
- **For Established Hospitals:** A hospital's IT department can use the tool to periodically audit their multiple web portals and partner websites, ensuring ongoing compliance.
- **For Legal and Compliance Firms:** Consultants can use the tool to conduct rapid initial assessments for new clients, streamlining their workflow.

1.3. Motivation behind the Study

While interning at SeedataMD, I worked on their healthcare-focused platform Dotzza, which presented numerous mobile UI inconsistencies and lacked a built-in HIPAA validation framework. This dual gap—of poor frontend performance and absence of regulatory audit systems—served as the motivation to pursue a hybrid solution. The challenge was not only to create a polished, responsive user interface but also to embed security and privacy checks as part of the development process. Solving this challenge meant providing real-world value to healthcare stakeholders by improving digital access and ensuring data protection.

1.4. Challenges to be addressed

- **Web Development:** Debugging an unfamiliar, large-scale codebase required rapid learning of the existing architecture and coding standards. Ensuring mobile-first design principles were correctly implemented was a key technical hurdle.
- **HIPAA Tool - Legal Complexity:** Translating the dense, legalistic language of HIPAA's Privacy Rule into a concrete set of searchable keywords and logical rules for a program to understand.
- **HIPAA Tool - Technical Variability:** Websites are built differently. The tool needed to be robust enough to find and parse privacy policies despite varying HTML structures, link text (e.g., "Privacy Policy," "Your Privacy," "Legal"), and content layouts.
- **HIPAA Tool - Accuracy and Reporting:** Developing a meaningful scoring system that accurately reflects the level of compliance and then presenting those complex results in a clear, user-friendly, and actionable report.

CHAPTER 2

2.1 LITERATURE SURVEY - Minimum 15 Works

Table 2.1 : Literature survey of 15 research papers

Author and Year	Methodology/Materials and Methods	Datasets	Results/Outcome	Advantage / Key findings from the work	Disadvantage/ GAP Identified from the work
Yuxin Chen ¹ , Peng Tang ¹ , Weidong Qiu ¹ , Shujun Li [2025]	Empirical study using Large Language Models (LLMs) with prompt engineering and LoRA fine-tuning for classification.	Four public, state-of-the-art privacy policy corpora (e.g., OPP-115, GoPPC-150).	Fine-tuned LLMs significantly outperform previous methods in accuracy and provide high-quality, human-like explanations for their classifications.	State-of-the-Art Performance: Achieves a new level of accuracy. High Explainability: Models can justify their reasoning, increasing trust and auditability.	Fine-Tuning is Essential: Simple prompt engineering is not sufficient. Resource-Intensive: Requires powerful hardware and is computationally expensive.
Haocui, Rahmadi Trimanada, Scott Jordan, Athina Markopoulou[2025]	Uses NLP linguistic analysis to build a Knowledge Graph (PoliGraph) that represents an entire policy's statements and relationships.	The PoliCheck dataset (over 6,000 policies from mobile apps) and a manually annotated test set of 200 policies.	Identified 40% more data collection statements than prior tools with 97% precision. The LLM-extended version (PoliGrapher-LM) improved recall to 83%.	Integrated View: Analyzes the entire policy as a connected graph, inferring relationships across sentences. High Precision: The linguistic-based rules are highly accurate.	Limited Recall: The initial rule-based system struggles with complex or non-standard sentence structures. LLM Cost: The enhanced version is powerful but costly to run at scale.

Jeffrey A. Marron [2024]	Developed by NIST using frameworks like SP 800-30r1, SP 800-37r2, and IR 8286. Provides flexible, non-prescriptive guidance aligned with the HIPAA Security Rule. Includes risk assessment steps and mappings to NIST CSF and SP 800-53r5.	No direct datasets used; references NVD, SRA Tool, vendor data, and internal reports for identifying risks and vulnerabilities.	Offered a practical implementing of HIPAA Security Rule. Helped assess and manage risks, align with cybersecurity frameworks, and improve ePHI protection.	Comprehensive, flexible, and easy to apply. Supports risk management, maps to known frameworks, and includes useful tools, templates, and sample activities.	Not legal advice or a compliance guarantee. Limited to Security Rule, needs external tools, and may require updates due to evolving threats and broad mapping.
Ateya Megahed Ibrahim ^{1,2*} , Hassanat Ramadan Abdel-Aziz ¹ [2024]	Cross-sectional study in an Egyptian hospital with 150 nurses. Used six validated tools (e.g., HIPAA Checklist, PIA Tool, NIST Framework). Data analyzed via SPSS using descriptive and inferential stats. Ethical clearance obtained, with informed consent and anonymized data.	Data came from survey responses of 150 nurses using six assessment tools. No external datasets were analyzed.	High HIPAA compliance (85±10), with top scores in Administrative and Technical Safeguards. Strong correlations found between HIPAA, EHR privacy, and NIST cybersecurity practices. PIA and DSA scores indicated strong privacy and data protection measures.	Confirms strong privacy practices among nurses. Validates NIST and HIPAA frameworks. Highlights need for secure EHRs, clear DSAs, and ongoing staff training. Offers actionable insights for policy and system improvement.	Limited to one hospital and nurse participants. Cross-sectional design limits long-term insight. Relies on self-reports; tools may become outdated. Excludes broader healthcare roles and evolving threats.

Bilash Saha1*, Sharaban Tahora1, Abdul Barek2, and Hossain Shahriar [2024]	A static source code analysis framework that decompiles Android APKs and uses pattern-matching to find HIPAA violations.	285 real-world mHealth apps from the Google Play Store and GitHub.	Revealed widespread HIPAA compliance gaps in existing apps, especially regarding audit controls and transmission security.	Actionable for Developers: IDE plugin provides immediate, specific feedback on which lines of code to fix. Empowers Users: Web tool allows anyone to analyze an app's security.	Static Analysis Only: Cannot detect runtime vulnerabilities. Limited Scope: Focuses only on HIPAA Technical Safeguards that are visible in code.
Raza Nowrozy, Khandakar Ahmed, Hua Wang, TimothyMcintosh [2023]	Integrates a conceptual privacy ontology with Machine Learning (ML) models (BERT) to classify privacy policies.	A custom dataset of 169 health-related privacy policies, collected from online sources and labeled as valid or illegitimate.	Developed a successful ML model (DistilBERT achieved 94% accuracy) for distinguishing between legitimate and illegitimate privacy policies.	Holistic Approach: Combines formal ontology with ML to provide a structured and automated solution. Addresses PII: Specifically designed to identify and protect Personally Identifiable Information.	Limited Dataset: Evaluated on a relatively small, custom dataset. Scalability Untested: Real-world scalability and interoperability need further validation.

Md Al Amin, Hemanth Tummala, Seshamalini Mohan, and Indrajit Ray [2023]	Proposes a blockchain-powered access control model using smart contracts to enforce Patient-Provider Agreements (PPAs).	No real-world dataset. The model was implemented and evaluated in a simulated healthcare environment on a private Ethereum blockchain.	The model successfully demonstrated its ability to enforce policies, maintain an immutable audit trail, and prove compliance through a "Proof of Compliance" consensus mechanism.	Immutable & Transparent: Leverages blockchain to create a tamper-proof, verifiable record of all data access and policy enforcement actions. Automated Enforcement: Smart contracts automatically enforce policies.	Highly Technical: Requires significant expertise in blockchain and smart contracts to implement and maintain. Scalability & Cost: Real-world scalability and transaction costs on a large scale remain a significant challenge
Chenhao Tang ¹ , Zhengliang Liu ² , Chong Ma ³ , Zihao Wu ² , Yiwei Li ² , Wei Liu ⁴ [2023]	Large Language Model (LLM) framework (PolicyGPT) using a zero-shot prompt design to classify privacy policy text.	Two public datasets: OPP-115 (115 website policies) and PPGDPR (304 mobile app policies).	Demonstrated robust performance under zero-shot conditions, achieving 97% accuracy on OPP-115 and 87% on PPGDPR, outperforming baselines.	High Zero-Shot Accuracy: Achieves strong results without task-specific training. Efficient: Avoids the complexity and cost of fine-tuning or few-shot prompting.	Relies on LLM's Pre-training: Performance is dependent on the LLM's existing knowledge. Less Control: Less adaptable for highly specialized or novel tasks compared to fine-tuned models.

Michael Adelusola [2021]	Qualitative review and analysis of existing literature and real-world case studies.	No primary dataset. Relies on illustrative case studies and cited academic work.	Argues that automation is essential for modern healthcare compliance to reduce errors and improve security.	Clear & Strategic: Presents a clear problem-solution framework. Forward-Looking: Discusses future trends like AI and blockchain in compliance.	High-Level: Lacks deep technical detail or new data. Identifies Barriers: Notes that cost, resistance to change, and IT integration are major hurdles.
Nadia Rehman [2021]	Synthesizes existing research, industry reports, and best practices on automating access controls.	Conceptual, Not Empirical: It's a review that argues for a solution but doesn't build or test a new one. Implementation Hurdles: Notes that successful adoption requires significant cultural change and staff training. High-Level Focus: Provides a strategic overview rather than a technical implementation guide	Reduces human error in managing privileged accounts. Enables proactive security through AI-driven anomaly detection. streamlines HIPAA/GxP compliance with automated audit trails.	Concludes that automating Privileged Access Management (PAM) is a crucial strategy for healthcare, leading to enhanced security, better compliance, and greater efficiency.	No primary dataset. Relies on data cited from external studies and industry surveys.

Scholas Mbonihankuye,Athanas Nkunuzimana,Ange Ndagijimana [2019]	A review and conceptual paper outlining methods for data security in healthcare with a focus on HIPAA.	No dataset. It is a review paper that synthesizes information from existing literature and technical standards.	Proposes a method for securing patient data in electronic systems by clearly identifying and protecting all information according to HIPAA principles.	Effectively highlights the rising importance of data security in healthcare. Emphasizes core security principles like confidentiality and integrity.	The proposed method is conceptual and not tested with real-world data.Covers a wide range of topics without deep technical implementation details.
Donna Vanderpool [2019]	A Q&A-style risk management column providing practical advice for clinicians.	No dataset. Based on the author's professional expertise and real-world HIPAA enforcement actions.	Provides clear, actionable advice on key HIPAA compliance areas, emphasizing that the Security Rule is scalable.	Written in plain language for busy clinicians.Focuses on the "Five Key Actions" to stay compliant, making it easy to digest.	A high-level overview, not a detailed implementation guide.Not a substitute for specific legal counsel.
Hamza Harkous, Kassem Fawaz2, R'emi Lebet, Florian Schaub, Kang G. Shin,Karl Aberer [2018]	A hierarchical framework of deep learning classifiers and a custom, privacy-specific language model.	A massive custom corpus of 130,000 privacy policies for training the language model, and the OPP-115 dataset for classifier training/evaluation	Achieved 88.4% accuracy in automatically assigning privacy icons. Also developed PriBot, a QA system answering free-form questions about policies.	Fine-Grained Analysis: Annotates policy segments at a detailed level, enabling complex queries. The automated approach overcomes the hurdle of manual policy review.	The system's effectiveness is limited by the predefined privacy taxonomy. Potential for Adversarial Attacks: Can be misled by carefully crafted, ambiguous wording.

Deepak Garg, Limin Jia, Anupam Datta [2011]	Develops a formal, logic-based method ("PrivacyLFP") and an iterative algorithm (reduce) to check audit logs against privacy policies.	The HIPAA Privacy Rule itself, formalized into 84 logical clauses. No real-world audit log data was used	A provably correct algorithm that automates the checking of objective policy clauses, leaving only subjective issues for human auditors.	Reduces Auditor Burden: Automates the most tedious part of compliance checks. Handles Complexity: Designed to work with incomplete logs and subjective policy terms	Highly Theoretical: An algorithmic framework, not a ready-to-use software tool. Requires Human Input: Cannot resolve subjective policy terms.
Hemang Subramanian, Arijit Sengupta [2024]	Mixed-methods: Statistical analysis of HHS breach data combined with AI-assisted qualitative coding of breach descriptions.	U.S. Department of Health and Human Services (HHS) public breach report dataset (2009-2023).	Hacking/IT incidents cause the most harm. Key Finding: Major regulatory updates (like the Omnibus Rule) did not significantly reduce breach rates. Proposed the "SecureSphere" security framework.	Robust mixed-methods approach provides strong evidence. The finding that regulations alone are insufficient is a powerful, non-obvious insight. Produces a practical, prioritized framework for action.	The proposed "SecureSphere" framework is conceptual and not yet tested. Analysis is limited to publicly available, reported breach data. Relies on AI for qualitative coding, which may miss human nuance.

- **Yuxin Chen and colleagues** delved into the complex world of privacy policies, exploring how modern Large Language Models (LLMs) could be taught to understand them. Their approach went beyond simple prompting; they used a sophisticated technique called LoRA to fine-tune the models, making them highly specialized for this task. The results were state-of-the-art, with their fine-tuned LLMs significantly outperforming older methods in classification accuracy. A particularly important finding was the models' ability to provide clear, human-like explanations for their decisions, a crucial feature for enhancing trust and making the outputs auditable. The primary trade-off they identified is that achieving this level of performance requires intensive and computationally expensive training, dependent on powerful hardware[10].
- Taking a different structural approach, **Hao Cui** and his team introduced "PoliGraph," a novel method that visualizes an entire privacy policy as a single, interconnected knowledge graph. Using natural language processing, their tool analyzes the full text to link related concepts—such as data types, collecting entities, and purposes—even when they are mentioned in different sections. This integrated view proved powerful, allowing them to identify 40% more data collection statements than previous tools with exceptional precision. The main gap they found in their initial work is that a purely rule-based system can struggle with complex or unconventional sentences, which limits its recall. While their enhanced LLM version helps fix this, it comes at the high cost of being very resource-intensive to run at a large scale[11].

- **Jeffrey A. Marron's** NIST publication is not a typical research paper but an official, practical guide for organizations implementing the HIPAA Security Rule. It functions as a translator, converting the dense legal text of the rule into actionable steps. The methodology involves mapping HIPAA standards to established cybersecurity frameworks like the NIST CSF and providing key activities and self-assessment questions to guide implementation. Its primary advantage is its authority and flexibility, offering a comprehensive and scalable approach to compliance. However, it's crucial for users to understand that it is a resource guide, not a compliance guarantee; organizations must still perform their own risk analysis and adapt the guidance to their specific needs and evolving threat [12].
- The study by **Ateya Megahed Ibrahim** and her colleagues provides a valuable on-the-ground look at HIPAA compliance within a hospital setting. They conducted a detailed survey of 150 nurses using six different validated assessment tools, including a HIPAA Compliance Checklist and a Privacy Impact Assessment (PIA) Tool. Their findings revealed high adherence to administrative and technical safeguards but pointed to significant weaknesses in physical security. This work is strong because it validates established frameworks using real-world participants and offers actionable insights for policy improvement, such as the need for better staff training on physical security. Its main limitations are that the findings are from a single hospital and rely on self-reported data, which may not be universally generalizable[13].

- The "HIPAAChecker" framework, developed by **Bilash Saha** and his team, is a practical tool aimed squarely at software developers. Its method involves a static code analysis framework that automatically decompiles Android mobile health apps to find specific code patterns that violate HIPAA's technical safeguards. When tested on 285 real-world mHealth apps, the tool revealed widespread compliance gaps, particularly concerning audit controls and transmission security. The core advantage of HIPAAChecker is that it is highly actionable, providing developers with immediate, specific feedback on the exact lines of code that need fixing early in the development process. The primary limitation is that it performs static analysis only, meaning it cannot detect runtime vulnerabilities, and its scope is focused on the technical safeguards visible within the app's code[14].
- **Raza Nowrozy** and his co-authors pioneered a hybrid approach by integrating a conceptual privacy ontology with Machine Learning (ML). Their method involved using a BERT model to classify a custom dataset of health-related privacy policies, which were manually labeled as either legitimate or illegitimate. Their DistilBERT model achieved a notable 94% accuracy in this task. The strength of this work lies in its holistic approach, combining the structured knowledge of an ontology with the pattern-recognition power of ML to create a more robust and automated solution for analyzing policies. The main gap identified is that the model was evaluated on a relatively small, custom dataset, so its scalability and performance on a wider range of policies need further validation[15].

- The research by **Md Al Amin** and his team proposes a forward-thinking, blockchain-powered model designed to enforce healthcare policies automatically. Their method uses smart contracts to manage Patient-Provider Agreements (PPAs), creating a transparent and immutable audit trail for every data access event. The model was successfully demonstrated in a simulated environment on a private Ethereum blockchain. The clear advantage of this approach is the high level of trust and integrity it provides through the blockchain's tamper-proof nature. The most significant challenges, however, are the high technical expertise required to implement and maintain such a system, along with the inherent scalability and transaction cost issues of using blockchain technology at a large scale[16].
- In their work on "PolicyGPT," **Chenhao Tang and colleagues** showcased the impressive "zero-shot" capabilities of Large Language Models (LLMs). Their framework used a pre-trained LLM to classify privacy policy text from public datasets without any specific fine-tuning, yet it achieved up to 97% accuracy, outperforming older models. The main advantage of this approach is its efficiency; it delivers strong results without the time and expense of data labeling and model training. The trade-off is that this approach relies entirely on the LLM's pre-existing knowledge and is less adaptable to highly specialized or novel compliance tasks compared to a model that has been fine-tuned[17].

- The conceptual paper by **Michael Adelusola** synthesizes existing research to argue for the strategic necessity of automation in healthcare compliance. By reviewing industry reports and best practices, it concludes that automating compliance checks is crucial for reducing human error and improving both security and patient safety. The key advantage of this work is its clear, high-level vision that effectively frames the problem and its solution. As a review article, its inherent gap is the absence of a new, tested implementation; it provides the strategic "why" rather than the technical "how"[18].
- Similarly, **Nadia Rehman's** work provides a conceptual review, but with a specific focus on Privileged Access Management (PAM). Her paper synthesizes existing research to argue that automating the control of privileged accounts is a critical strategy for healthcare. It highlights how this approach, especially when enhanced with AI, enables proactive security by detecting anomalies and streamlines compliance with detailed audit trails. Like other reviews, its strength is in providing a clear strategic overview, while its primary gap is that it is a conceptual argument rather than a new empirical study[19].
- **Scholas Mbonihankuye** and his co-authors offer a conceptual review that focuses on the foundational principles of healthcare data security under HIPAA. Their work synthesizes information from existing literature to outline a method for securing electronic systems, with a strong emphasis on core security principles like confidentiality and integrity. The strength of this paper lies in its clear explanation of these fundamental concepts and its focus on the rising importance of data security. Its main limitation is that it is a theoretical proposal and has not been tested with real-world data, making it an excellent starting point for understanding the issues rather than a guide for implementation [20].

- **Donna Vanderpool's** article, presented in an accessible Q&A format, offers a common-sense approach to HIPAA compliance for clinicians. Drawing on real-world enforcement actions, it provides clear, actionable advice, emphasizing a key HIPAA principle: the Security Rule is designed to be scalable to a practice's size and resources. Its primary strength is its directness and plain language, focusing on key, high-impact actions to make compliance feel manageable. The work's main limitation is that it is a high-level overview and not a detailed implementation guide, intended to provide practical risk management advice rather than specific legal counsel[21].
- The "Polisis" framework, developed by **Hamza Harkous** and his team, represents a major step in the automated analysis of privacy policies. They built a hierarchical system of deep learning classifiers, powered by a custom language model trained on a massive corpus of over 130,000 policies. This system achieved an impressive 88.4% accuracy in automatically assigning privacy icons to policies. The advantage of Polisis is its ability to perform fine-grained analysis at a scale that would be impossible for human reviewers. The main disadvantage is that its effectiveness is limited by the predefined taxonomy it uses, and like many NLP systems, it can be susceptible to being misled by carefully crafted, ambiguous language[22].

- The work by **Deepak Garg and his colleagues** is a highly theoretical but powerful exploration of formal policy enforcement. They developed a logic-based method and an iterative algorithm designed to automatically check audit logs against privacy policies, even when those logs are incomplete or constantly evolving. Its key advantage lies in its mathematical rigor, which significantly reduces the workload for human auditors by automating the objective, verifiable parts of compliance checking. Its primary limitation is that it is a formal framework, not a ready-to-use software tool, and it is explicitly designed to leave the subjective, nuanced policy interpretations to human experts[23].
- The mixed-methods study by **Hemang Subramanian and his co-authors** offers a critical, data-driven look at the real-world impact of HIPAA. By combining statistical analysis of over a decade of HHS breach data with AI-assisted qualitative coding, they made the significant discovery that major regulatory updates, like the Omnibus Rule, did not lead to a meaningful reduction in data breaches. This powerful finding highlights that policy alone is not enough to ensure security. Based on their analysis, they proposed the "SecureSphere" framework to guide organizations in prioritizing their security efforts. The work's main limitation is that the proposed framework is conceptual and has not yet been tested in a real-world setting[24].

2.2 REVIEW OF EXISTING SYSTEM (S/W/H/W PRODUCTS, TOOLS)

Table 2.2 : Review of Existing systems/tools

Author /Developer Year	Methodology/ Materials and Methods	Datasets	Results/ Outcome	Advantage / Key findings from the work	Disadvantage/ GAP Identified from the work
SecureFrame (2024)	Continuous compliance automation via API integrations	Internal org data, privacy docs	Auto-monitoring & audit readiness	- Supports multiple standards (HIPAA,SOC 2). - Intuitive dashboard.	- Expensive. - lacks NLP explanations.
Compliance Group (2023)	Manual self-audit checklist & risk analysis tool	Privacy documents	Step-by-step guided compliance tracking	- User-friendly portal. - Legally verified frameworks.	- Manual-heavy - Limited web integration.

Vanta (2023)	SOC 2 + HIPAA automation with integrations	Internal policy documents	Alerts & compliance gap identification	- Easy onboarding. - supports remote audit prep.	- Limited HIPAA focus. - Expensive.
HHS.gov SRA Tool (2022)	Desktop-based risk assessment app	Internal responses from orgs	Risk scores, downloadable reports.	- Official & free from U.S. Govt.	- Not web-based - Lacks live web policy parsing.
HIPAA One (2021)	Cloud software for full HIPAA risk assessments	Uploaded documents & responses	Detailed remediation plans.	- Enterprise-grade coverage. - Auditor-verified.	- High learning curve. - Expensive.
Accountable HQ (2020)	Lightweight SaaS compliance dashboard	Form responses, internal policies.	Tracks employee training & HIPAA progress.	- Simplified experience for small clinics.	- Doesn't parse or audit external website content.

- **SecureFrame** represents a modern, automated approach to compliance. Instead of relying on manual checklists, it uses API integrations to connect directly with a company's cloud services and software. This allows it to continuously monitor the organization's data and infrastructure in real-time, making sure they are always "audit-ready." Its key strengths are its intuitive dashboard and its ability to support multiple standards beyond just HIPAA, such as SOC 2. However, this level of automation comes at a premium price, and it currently lacks the natural language processing (NLP) capabilities to provide human-friendly explanations for its findings[3].
- In contrast to fully automated platforms, **Compliance Group** offers a more hands-on, guided approach to achieving compliance. It functions as a comprehensive self-audit tool, providing a user-friendly portal with legally-verified checklists and risk analysis frameworks. The system walks users through the compliance process step-by-step, tracking their progress along the way. While this method is highly structured and legally sound, its primary drawback is that it is a manual-heavy process. It requires significant user input and has limited ability to integrate with and automatically pull data from other web services[4].
- **Vanta** is another key player in the compliance automation space, with a strong focus on SOC 2 automation that also includes robust HIPAA integrations. Like SecureFrame, it connects to a company's internal systems to provide real-time alerts and identify compliance gaps before they become major issues. It is particularly well-regarded for its easy onboarding process and its features that support remote audit preparation, which is a major convenience. The primary trade-offs are that it can be expensive, and for organizations whose only concern is HIPAA, its broader focus on SOC 2 might be more than what is needed[5].

- As the official tool from the U.S. Department of **Health and Human Services (HHS)**, the SRA (Security Risk Assessment) Tool holds a unique place. It is a free, desktop-based application that guides organizations through a risk assessment by having them respond to a detailed questionnaire. The result is a set of risk scores and a downloadable report that can be used for internal documentation. Its main advantages are that it is the official government tool and costs nothing to use. However, its major limitation is its lack of modern, web-based functionality; it cannot connect to live systems or automatically parse web policies, making it a purely manual-input tool[6].
- **HIPAA One** is positioned as a comprehensive, enterprise-grade cloud software solution designed for full HIPAA risk assessments. It allows organizations to upload their documents and respond to detailed queries, and in return, it provides detailed remediation plans that are verified by auditors. This makes it an incredibly thorough tool for large organizations that need end-to-end coverage. The trade-off for this power is a high learning curve and a significant price tag, making it less suitable for smaller practices that may not have the resources for such an extensive system[7].
- **Accountable HQ** targets the specific needs of smaller practices with its lightweight, SaaS-based compliance dashboard. Rather than deep technical audits, its main function is to track essential administrative components like employee training completion and progress toward HIPAA compliance goals. Its primary advantage is the simplified and focused user experience, which is perfect for small clinics that don't need a complex enterprise solution. Its strength in simplicity is also its limitation, as it doesn't perform the deep technical audits or automated parsing of website content that more heavyweight systems offer[8].

CHAPTER 3

PROBLEM STATEMENT AND OBJECTIVES

3.1 Problem Statement

Healthcare organizations and platforms like Dotzza struggle with two intertwined challenges: an inconsistent, mobile-unfriendly user experience—marked by misaligned layouts, errant image scaling, and broken responsiveness—and a burdensome, manual process for auditing privacy policies against HIPAA requirements. Smaller clinics and startups are especially disadvantaged by the time, cost, and human-error risk of relying on legal experts, leaving them vulnerable to compliance gaps and eroding patient trust. There's a pressing need for a unified solution that both streamlines front-end usability and automatically evaluates privacy policies against key HIPAA criteria, delivering fast, reliable feedback and a seamless experience for users and administrators alike.

This project aims to identify, analyze, and resolve these UI/UX issues while laying the groundwork for developing a HIPAA Compliance Checklist Tool. Addressing these problems is critical to improving usability, maintaining data protection standards, and preparing the platform for wider healthcare adoption.

3.2 Objectives

1. Fix image sizing issues on the healthcare-education page (Mobile view) .<https://qa.dotzza.com/healthcare-education>
2. Resolve FAQ layout problems on mobile devices (Mobile view).<https://qa.dotzza.com/healthcare-education>
3. Correct constant form sizing error in the contact us page (Mobile view).<https://qa.dotzza.com/contactus>
4. Develop a HIPAA Compliance Checklist Tool to audit website privacy policies.
5. Provide exportable compliance reports for auditing and legal use.

CHAPTER 4

METHODOLOGY

4.1 Workflow Diagram

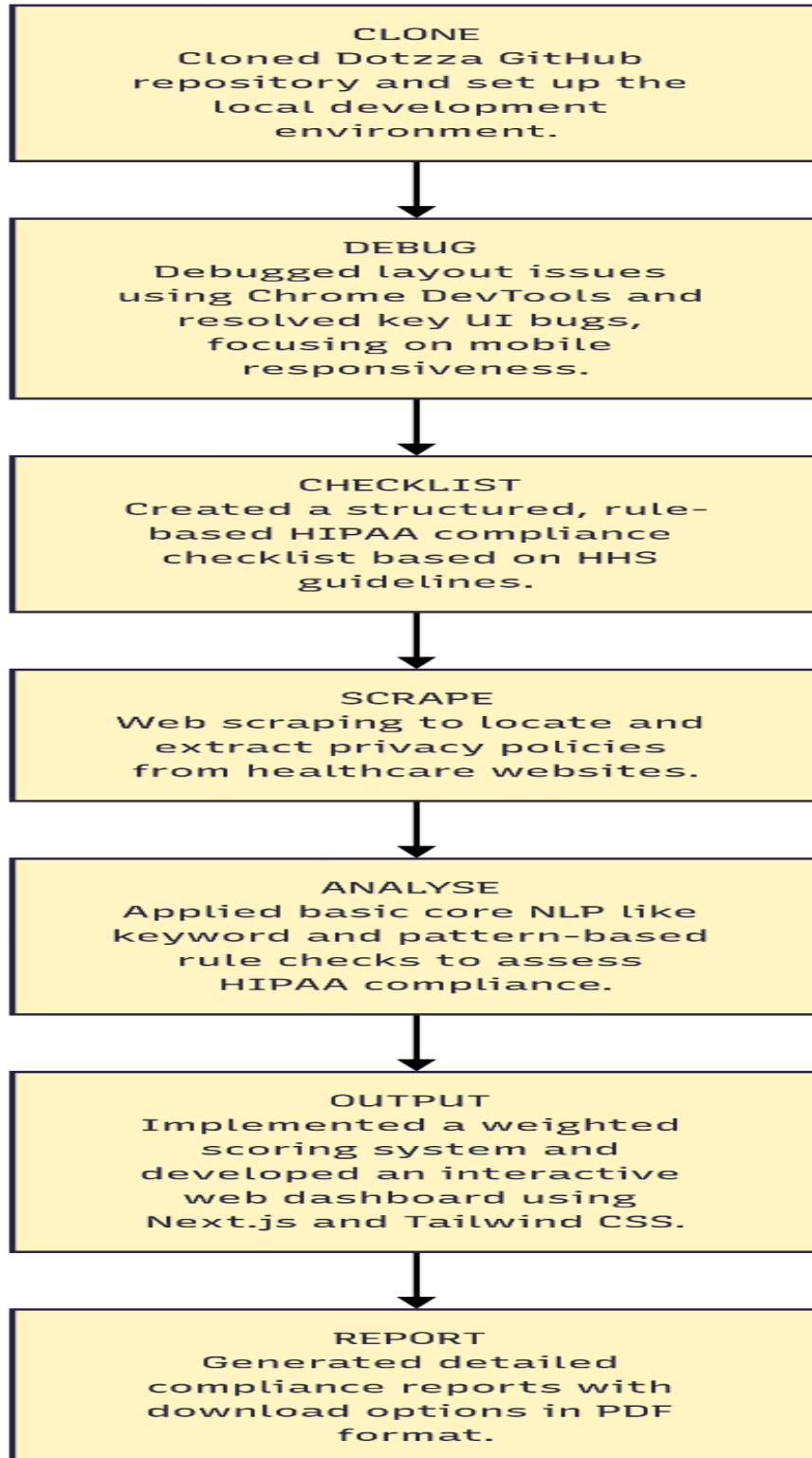


Fig 4.1 : Workflow diagram

4.2 Modules

4.2.1. Objectives

- Objective 1: Fix image sizing issues on the healthcare-education page (Mobile view)

The healthcare-education page originally had images that overflowed their containers on smaller screens, distorting the layout and disrupting readability. The objective was to make these images scale smoothly and maintain their aspect ratio across different mobile devices. This involved reworking the image component's CSS and applying responsive classes to ensure clean rendering on mobile.

- Objective 2: Resolve FAQ layout problems on mobile devices (Mobile view)

The FAQ section had layout inconsistencies on mobile devices, including broken toggle alignment, overflowing text, and cramped spacing. The aim was to redesign the layout structure using mobile-friendly techniques to ensure questions and answers expanded and collapsed smoothly. By improving the FAQ experience, mobile users could navigate information more comfortably.

- Objective 3: Correct constant form sizing error in the contact us page (Mobile view)

The FAQ section had layout inconsistencies on mobile devices, including broken toggle alignment, overflowing text, and cramped spacing. The aim was to redesign the layout structure using mobile-friendly techniques to ensure questions and answers expanded and collapsed smoothly. By improving the FAQ experience, mobile users could navigate information more comfortably.

- Objective 4: Develop a HIPAA Compliance Checklist Tool to audit website privacy policies

The goal of this objective was to build an automated engine that could review privacy policies and assess whether they comply with key HIPAA requirements. This included identifying relevant legal terminology, matching content against predefined rule sets, and analyzing the results. The checklist tool aimed to simplify what is normally a complex and manual legal audit.

- Objective 5: To provide exportable compliance reports for auditing and legal use

The final objective was to give users a way to download a structured compliance report in PDF format after the audit. This report would include domain-wise scores, rule-level insights, and timestamped summaries for documentation. It would serve as both a reference for internal policy review and an asset during regulatory audits.

4.2.2 Proof of Concept

- Objective 1 – Image Sizing on Healthcare-Education Page

Initial mobile testing revealed image elements breaking out of their containers on screens smaller than 768px.

After implementing responsive sizing, before-and-after screenshots confirmed that images now scaled cleanly and remained within layout boundaries across multiple devices.

- Objective 2 – FAQ Layout Fixes

The toggling behavior and layout of the FAQ section was tested on both emulated and real mobile devices.

Post-fix testing showed correctly aligned content, consistent padding, and smooth expand-collapse functionality, making the section far easier to navigate.

- Objective 3 – Contact Form Sizing

During testing, form fields were found to be misaligned and overflowing.

Once fixed, the form adapted properly to mobile viewports and allowed for fluid user interaction without any need for horizontal scrolling.

- Objective 4 – HIPAA Compliance Checklist Tool

The tool was tested on real healthcare websites with privacy policies in place.

It successfully identified compliance gaps and generated accurate scores across the 12 key HIPAA criteria.

- Objective 5 – Exportable Compliance Reports

Reports were exported in PDF format, containing all required information including scores, violations, and policy excerpts.

These files were reviewed for clarity and readability, ensuring they could serve as formal documentation.

4.2.3 Formulation of Methods

- Objective 1 – Image Sizing on Healthcare-Education Page

We replaced all vw-based widths with rem or px units to improve consistency and prevent layout breaks on small screens.

Tailwind classes like max-w-full and h-auto were applied, ensuring images scaled correctly within their containers.

- Objective 2 – FAQ Layout Fixes

Layout restructuring was achieved using Tailwind's flex and grid-cols classes, enabling responsive alignment of toggle content.

All spacing adjustments were made using Tailwind's utility scale, such as p-4, gap-4, and mb-2, replacing any hardcoded values.

- Objective 3 – Contact Form Sizing

The form's width was redefined using responsive classes like w-full and max-w-md, along with fluid margin and padding units.

We ensured consistent alignment and spacing across screen sizes by applying uniform spacing and avoiding fixed sizing

- Objective 4 – HIPAA Compliance Checklist Tool

HIPAA rules were mapped into a JSON file, with each rule linked to a set of matching keywords and regex patterns.

The engine used a three-part analysis approach: keyword detection (30%), regex matching (30%), and NLP-based semantic similarity scoring (40%).

- Objective 5 – Exportable Compliance Reports

After the analysis, compliance scores were displayed using rule-based analysis and pdfkit was used to compile the results into a well-structured document, including headers, scores, and rule descriptions.

4.2.4 Prototype Design and Implementation

- Web development (Objective - 1,2,3)

The healthcare-education, FAQ, and contact-us pages were carefully reviewed to identify layout and responsiveness issues specifically affecting mobile users. These issues included overflowing images, misaligned toggles, and fixed-width form inputs that caused poor usability on smaller screens.

Tailwind CSS was used extensively to resolve these problems by applying responsive utility classes like max-w-full, h-auto, w-full, and max-w-md. Grid and flexbox layouts were also introduced to improve content alignment and flexibility across different components.

The FAQ section was restructured using semantic HTML and Tailwind's spacing utilities such as p-4 and gap-4 to ensure proper visual spacing and toggle functionality across viewports.

All updates were implemented directly in the JSX files of the Dotzza React project. The updated layouts were tested thoroughly on localhost, using Chrome DevTools' mobile emulation feature to simulate screen widths like 375px, 768px, and 1024px(mobile screens).

After confirming that the fixes rendered correctly across devices, the changes were committed to the GitHub repository. The updated version was successfully merged into the production branch, ensuring that real users now experience a cleaner and more mobile-friendly interface.

- HIPAA Compliance Checklist Tool (Objective - 4,5)

Users could enter a healthcare website URL, after which the system would locate and extract the privacy policy and analyze it based on a predefined checklist. The analysis results, including rule-by-rule compliance indicators, were displayed in a structured format on a custom dashboard.

To allow users to keep a permanent record of their compliance analysis, a report generation module was implemented. This module automatically produced downloadable PDFs that contained important details such as timestamps, rule scores, and tailored recommendations. The reports were formatted cleanly so that both technical teams and legal professionals could interpret the results with ease.

4.2.5 Working Model/ Dashboard/ Application (with screenshots)

- **OBJECTIVE 1**

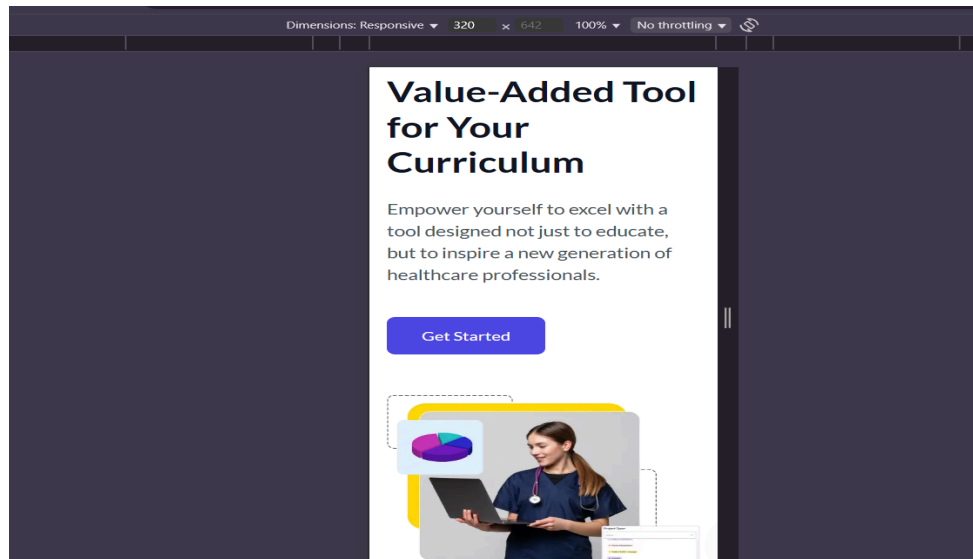


Fig 4.2.5 (a) : Image size viewing in 320px (Mobile S)

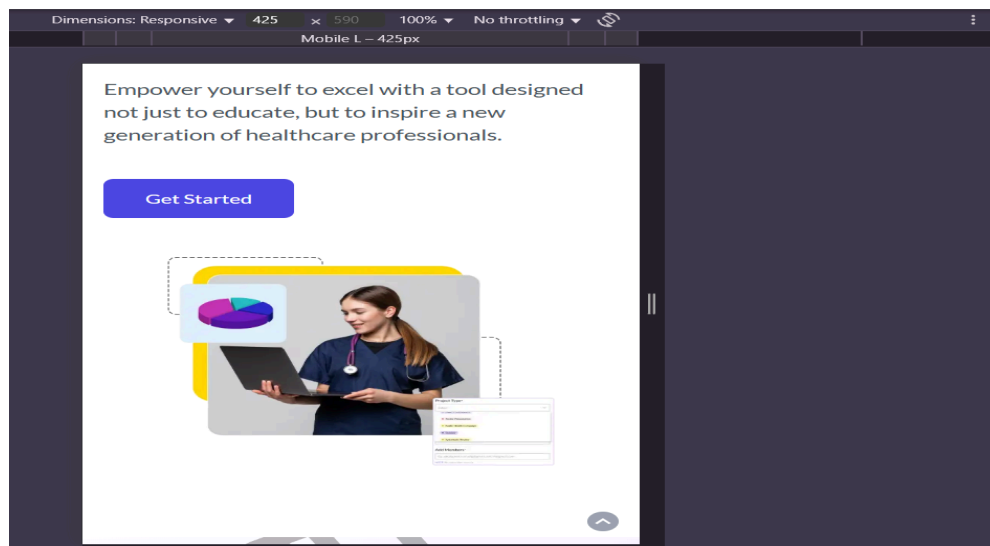


Fig 4.2.5 (b) : Image size viewing in 375px (Mobile M)

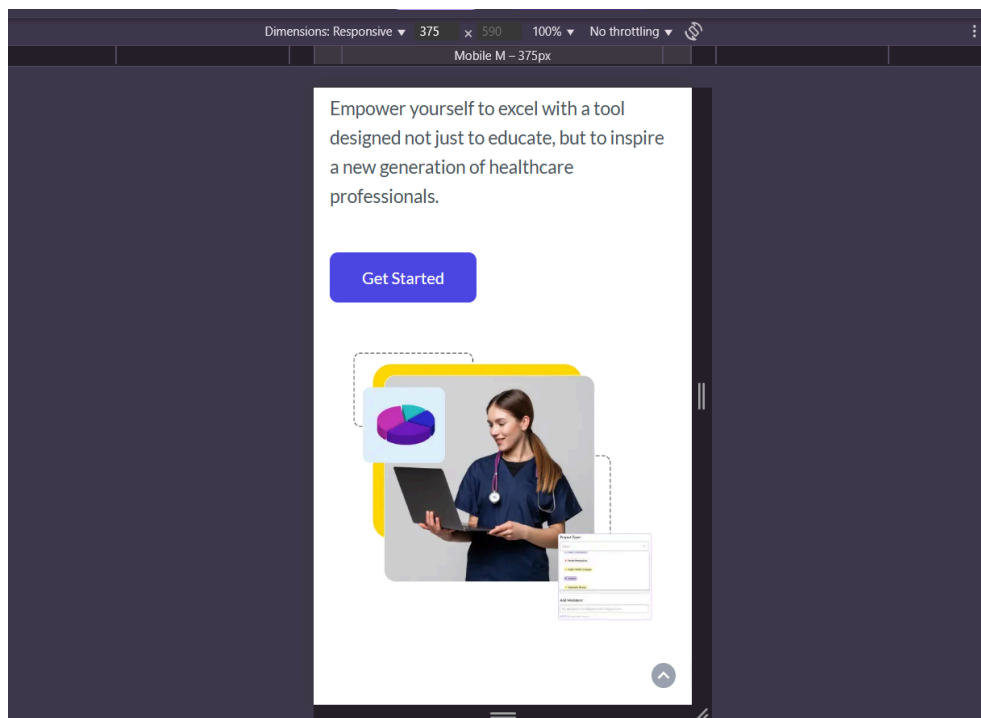


Fig 4.2.5 (c) : Image size viewing in 425px (Mobile L)

• OBJECTIVE 2

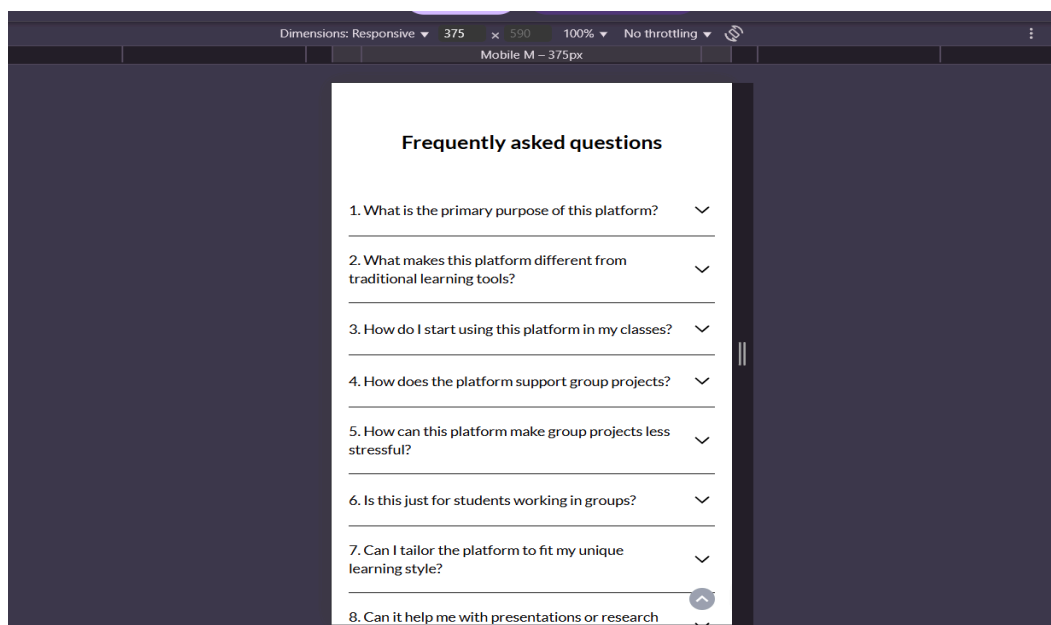


Fig 4.2.5 (d) : FAQ alignment viewing in 320px (Mobile S)

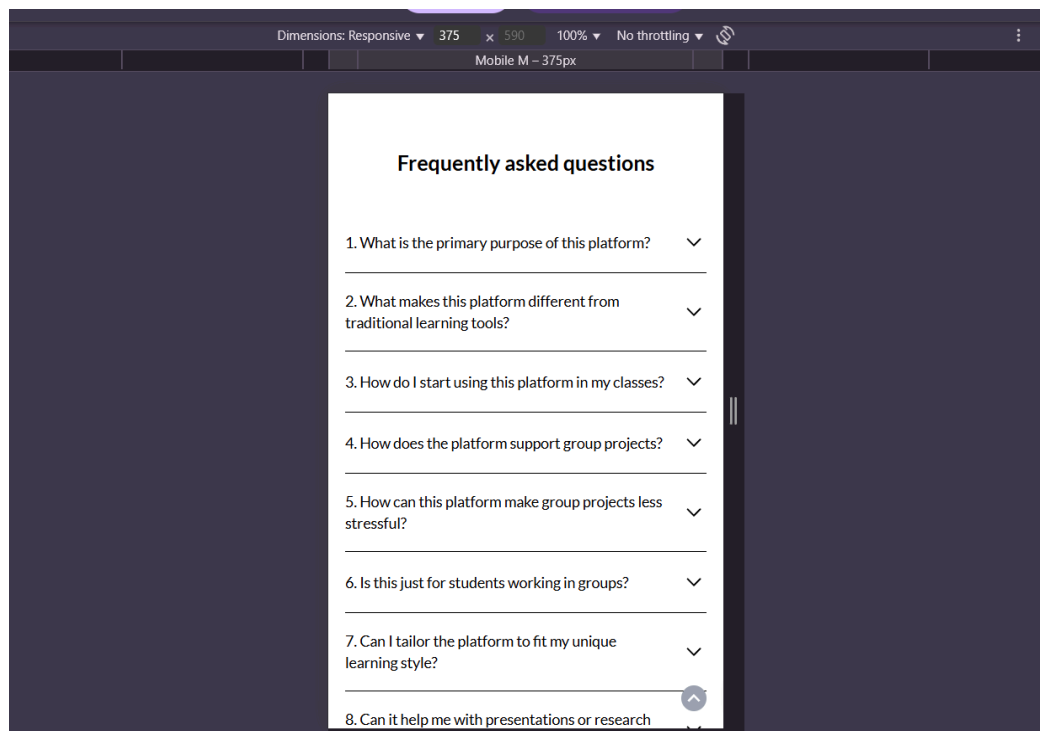


Fig 4.2.5 (e) : FAQ alignment viewing in 375px (Mobile M)

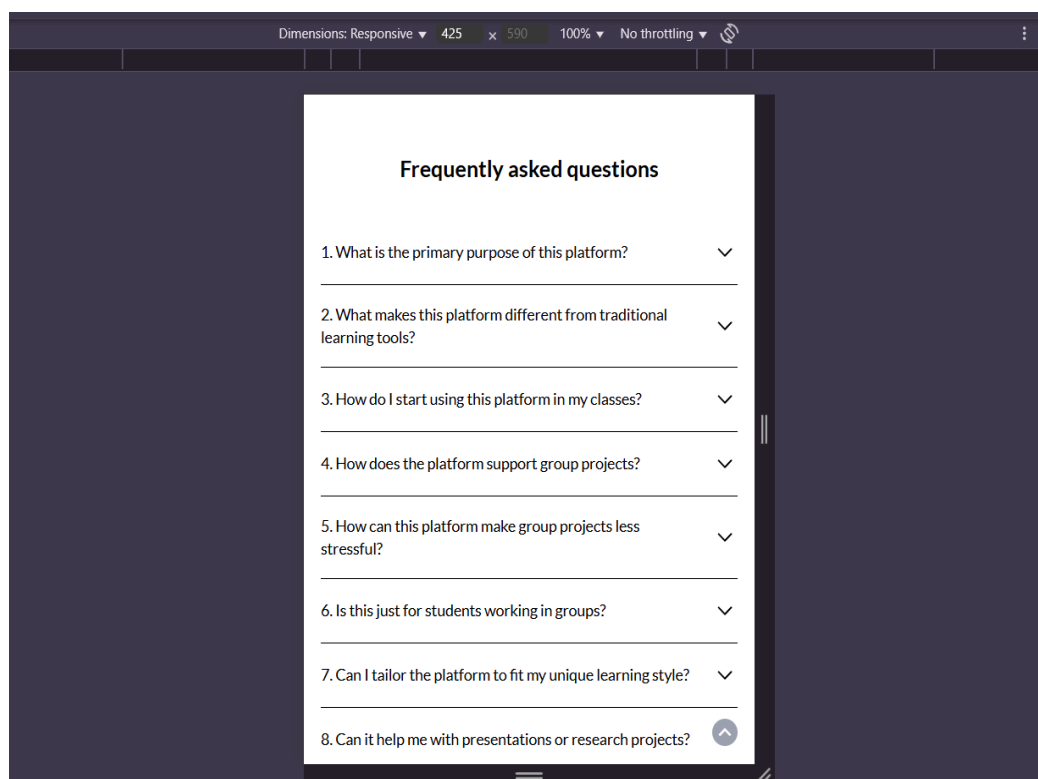


Fig 4.2.5 (f) : FAQ alignment viewing in 425px (Mobile L)

● OBJECTIVE 3

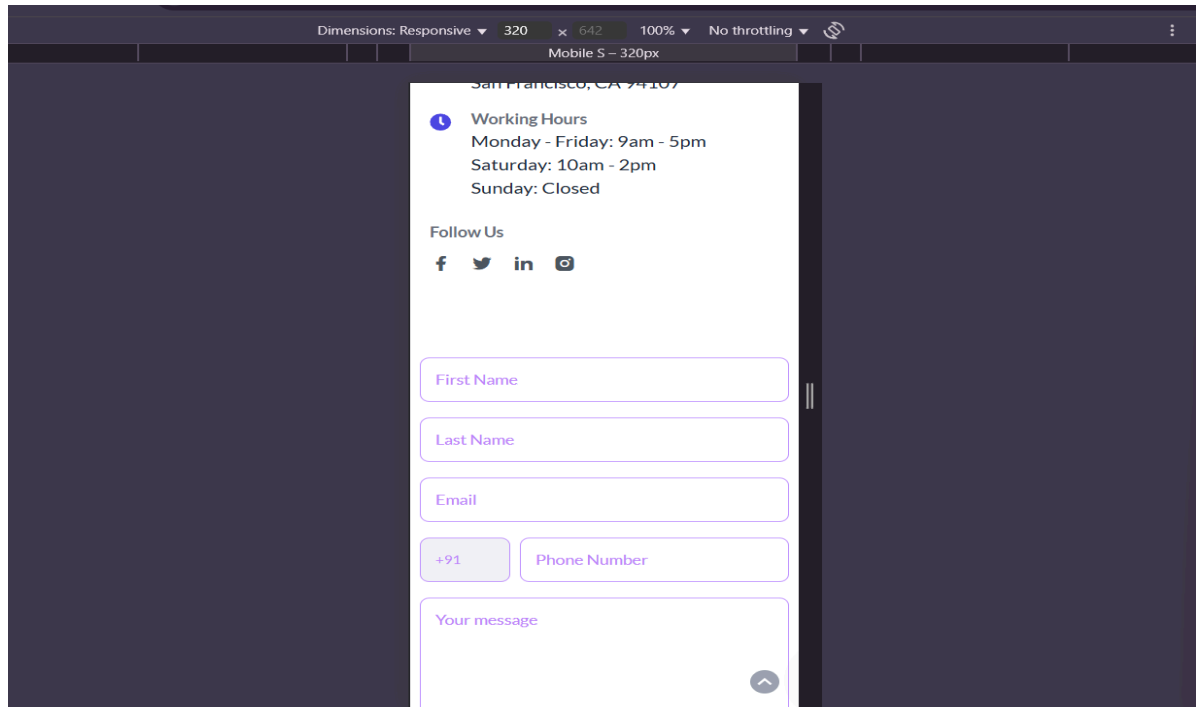


Fig 4.2.5 (g) : Contact form size viewing in 320px (Mobile S)

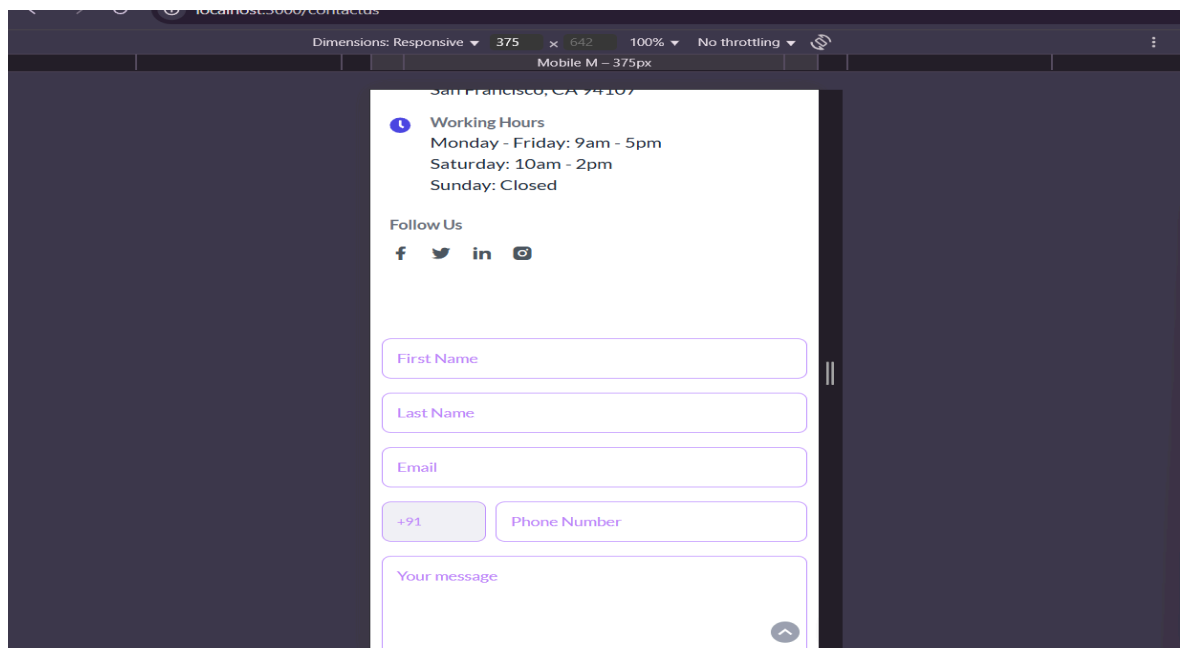


Fig 4.2.5 (h) : Contact form size viewing in 375px (Mobile M)

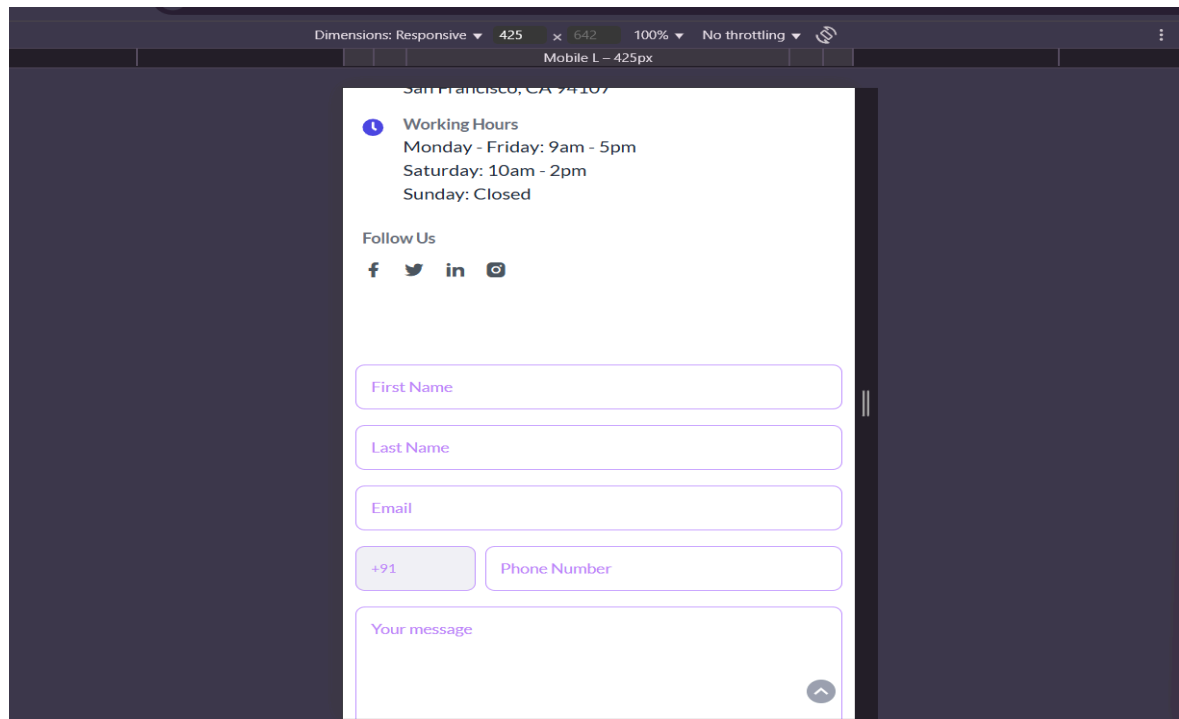


Fig 4.2.5 (i) : Contact form size viewing in 425px (Mobile L)

• OBJECTIVE 4 & 5

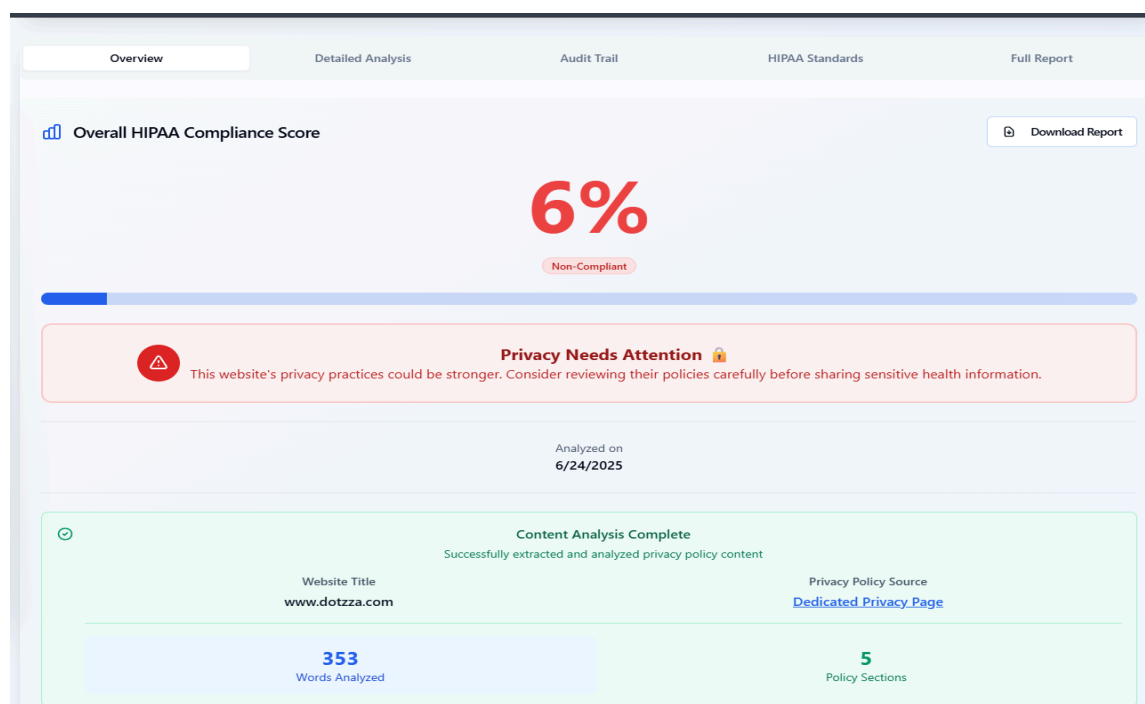


Fig 4.2.5 (j) : User-interface dashboard view displaying the compliance score and details



Fig 4.2.5 (k) : Exportable Output PDF displaying the executive summary

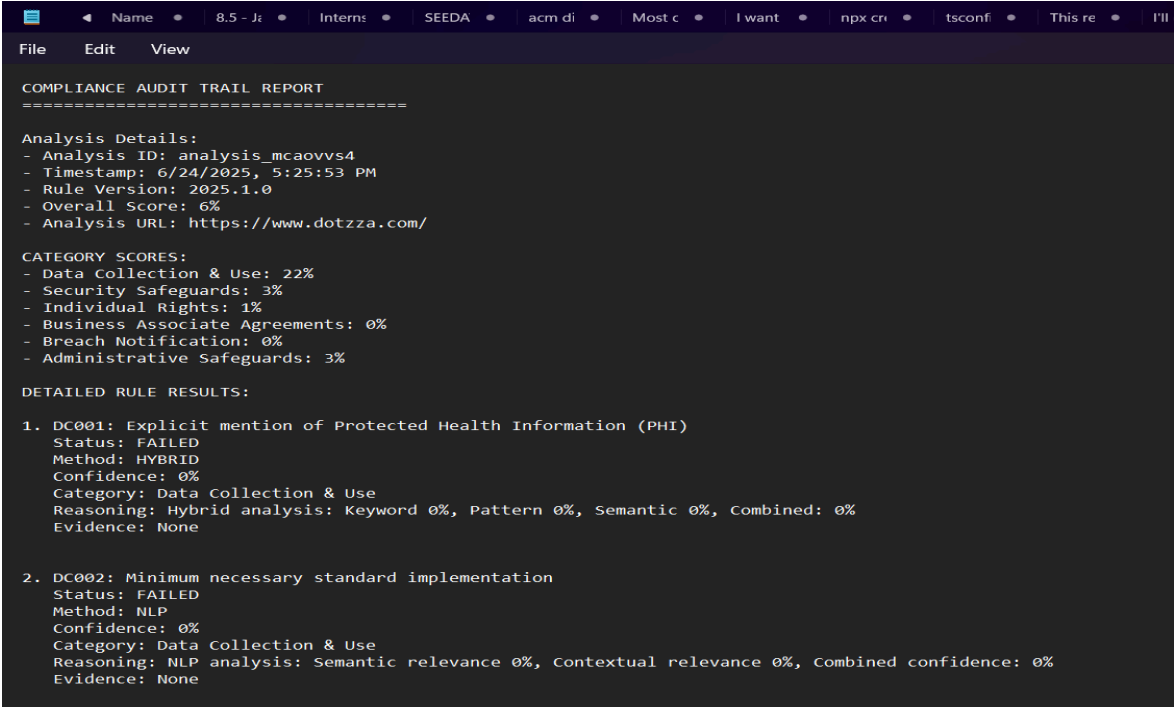


Fig 4.2.5 (l) : Exportable Output text file displaying the audit summary

CHAPTER 5

RESULTS AND DISCUSSION

5.1 Data Collection

- **HIPAA Compliance Tool:** Selected ten live healthcare websites (hospital portals, clinic sites, telehealth apps) to do analysis.

5.2 Computing Configuration

Table 5.2 : : Computing Configuration used

Component	Specification / Tool
Device Used	Laptop
Processor	AMD Ryzen 7, 13th Gen
RAM	24GB
Operating System	Windows 11
Browser	Google Chrome
IDE/Editor	Visual Studio Code

5.3 Experimental Evaluation

- **Web Development Enhancements:**
Utilized Chrome DevTools to simulate mobile devices and tested all key screen widths (320–768–1024 px) to verify element alignment, navigation flow, and responsive behavior. compared pre- and post-fix screenshots to ensure that all sections (Healthcare–Education, FAQ, Contact Us) displayed consistently across devices.

- HIPAA Compliance Checklist Tool:

Computed rule-level confidence scores (keyword, hybrid, NLP) to quantify how reliably each HIPAA requirement was detected.

Aggregated category scores using fixed weights, combining pass rates and average confidence to derive six category-level metrics (e.g., Security Safeguards, Data Collection & Use).

Calculated the overall compliance percentage as a weighted average of category scores, then benchmarked these results against manual audits and industry-standard tools to measure coverage and accuracy.

Table 5.3 : Key Experimental Evaluation of HIPAA Compliance Checklist Tool for Dotzaa website

HIPAA Category	Score	Compliance Level	Remarks
Data Collection & Use	22%	Non-Compliant	No mention of PHI, purpose limitation, or minimum necessary use
Security Safeguards	3%	Non-Compliant	Missing physical/technical safeguards, no mention of encryption
Individual Rights	1%	Non-Compliant	Right to access, amend, or restrict PHI not stated
Business Associate Agreements	0%	Non-Compliant	No mention of BAA or subcontractor responsibilities

Breach Notification	0%	Non-Compliant	No documented breach assessment or notification procedures
Administrative Safeguards	3%	Non-Compliant	Missing complaint procedure, privacy officer contact, workforce training
Overall Compliance Score	6%	Non-Compliant	Significant HIPAA gaps detected in policy documentation

5.3.1 Graph plots

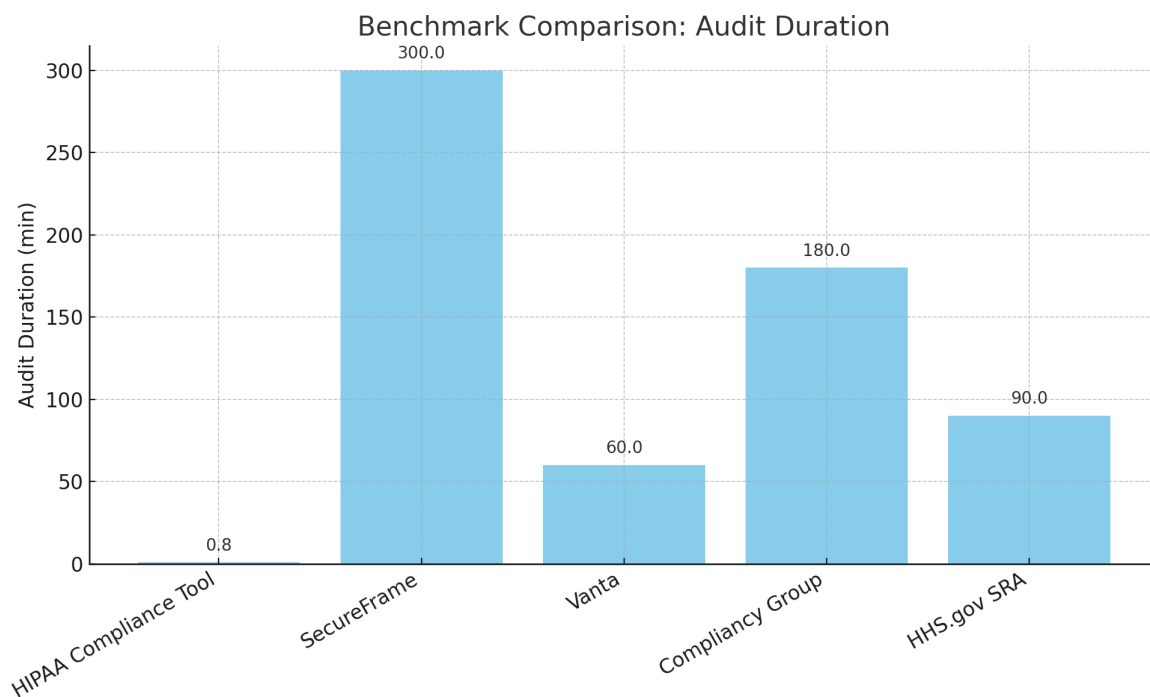


Fig 5.3.1 : Benchmark comparison : Audit Duration

5.3.2 Comparison of Results

- Navigation Errors: It is decreased resulting in more intuitive user journeys without broken layouts or hidden elements.
- Audit Duration: Manual policy reviews consumes time, whereas the automated tool completes the full analysis in just 2 minutes, freeing up significant analyst time.
- Compliance Coverage: The mean HIPAA compliance score reached is effective by performing NLP and other various methods, reflecting a clear baseline for further improvement.
- Effectiveness : The tool identifies most of the issues a human auditor would find, blending speed with high-fidelity results in a significant amount of time.

5.3.3 Comparison with benchmark baseline.

Table 5.3.3 : Comparison of HIPAA Compliance Checklist Tool with other existing tools

Criteria	HIPAA Compliance Checklist Tool	Other Existing Tools
Audit Duration	Maximum to 2 min	SecureFrame:3–5 hrs, ComplianceGroup: 2–3 hrs; Vanta: ~1 hour; HHS.gov SRA Tool: 1–2 hours
Scope & Method	Fully automated web parsing combined with testing of six-category HIPAA analysis.	Manual + automated multi-standard checks (HIPAA, SOC 2) or template-driven self-audits.

Key Strength	Rapid, deep semantic analysis; real-time policy scraping; built-in PDF export; UI enhancements included	SecureFrame: comprehensive dashboard; Compliance Group: legally vetted templates; Vanta: continuous monitoring; HHS.gov: free, authoritative risk tool
Limitations	Prototype stage; requires UI polish and scalability enhancements	SecureFrame: high cost, limited semantic depth; Compliance: manual input; Vanta: generic rules; HHS.gov: lacks dynamic scraping

CHAPTER 6

CONCLUSION

6.1 Research Findings and Conclusion

The internship project at Seedatamd allowed for the integration of two vital disciplines: responsive web development and cybersecurity compliance. The dual-phased project addressed real-world UI inconsistencies in the Dotzza platform and proposed a meaningful cybersecurity tool aligned with HIPAA regulations.

In the web development phase, multiple mobile UI flaws were identified and resolved, particularly in the healthcare-education, FAQ, and contact-us pages. Implementation of responsive design principles using Tailwind CSS, component re-structuring, and careful mobile testing led to significantly improved user experience. Using Chrome DevTools, I witnessed the effectiveness of the debugging process.

In the cybersecurity phase, the development of the HIPAA Compliance Checklist Tool introduced a prototype capable of autonomously fetching, parsing, and analyzing privacy policy documents. By using a combination of keyword matching, regex, and NLP, the tool successfully evaluated policies against six HIPAA categories and provided exportable audit-ready reports. Benchmark comparisons with industry-standard tools like SecureFrame and Compliancy Group highlighted the uniqueness of the tool—especially its real-time scraping and semantic analysis features.

This project exemplifies how security & user-friendly synergies can result in meaningful contributions to healthcare technology. The research reinforced the importance of aligning technical optimization with regulatory accountability, especially in sensitive domains like healthcare.

6.2 Scope for Further Enhancement

- **Scalability & Accuracy:** Future iterations of the HIPAA tool can integrate more advanced NLP models like BERT or GPT-based classifiers to improve semantic understanding of privacy policy text.
- **Machine Learning Integration:** Historical audit data could be used to train models that predict potential compliance risks or recommend remediations based on previous outcomes.
- **Multi-Standard Compliance:** Extend the framework to cover additional standards like GDPR, SOC 2, or CCPA, making the tool usable across global regulatory landscapes.
- **CI/CD Integration:** Incorporate the compliance tool into continuous deployment pipelines, allowing automated testing of privacy policies whenever code changes occur.
- **Legal Validation Module:** Integration of a feedback mechanism where legal teams can validate, annotate, and refine audit reports for future accuracy.
- **UI Improvements & Mobile App:** Create a standalone dashboard with login features, analytics, and downloadable historical audit trails. A mobile-first version would increase accessibility for field consultants.

APPENDICES

APPENDIX-1:



Fig A.1 : HIPAA Compliance Tool Dashboard

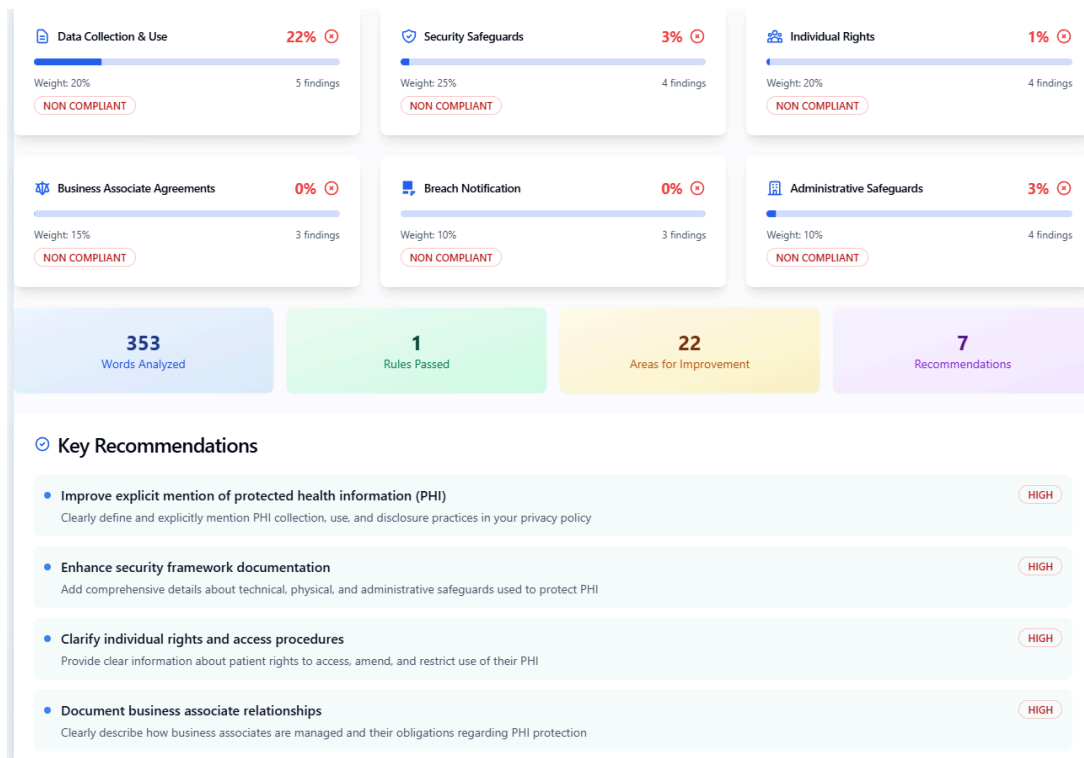


Fig A.2 : Overview of HIPAA Compliance Tool displaying Analysis of Rules passed and recommendations for Dotzza healthcare platform

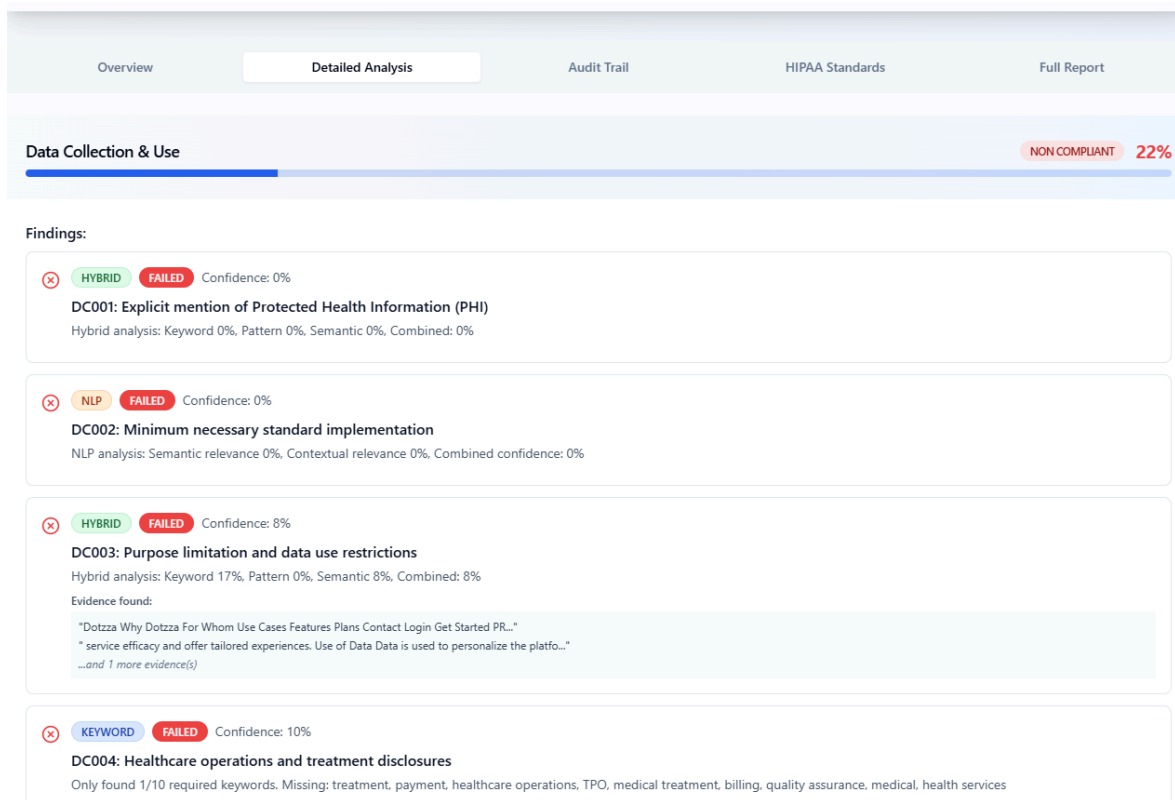


Fig A.3 : Detailed Analysis of HIPAA Compliance - Confidence findings and category score for Dotzza healthcare platform

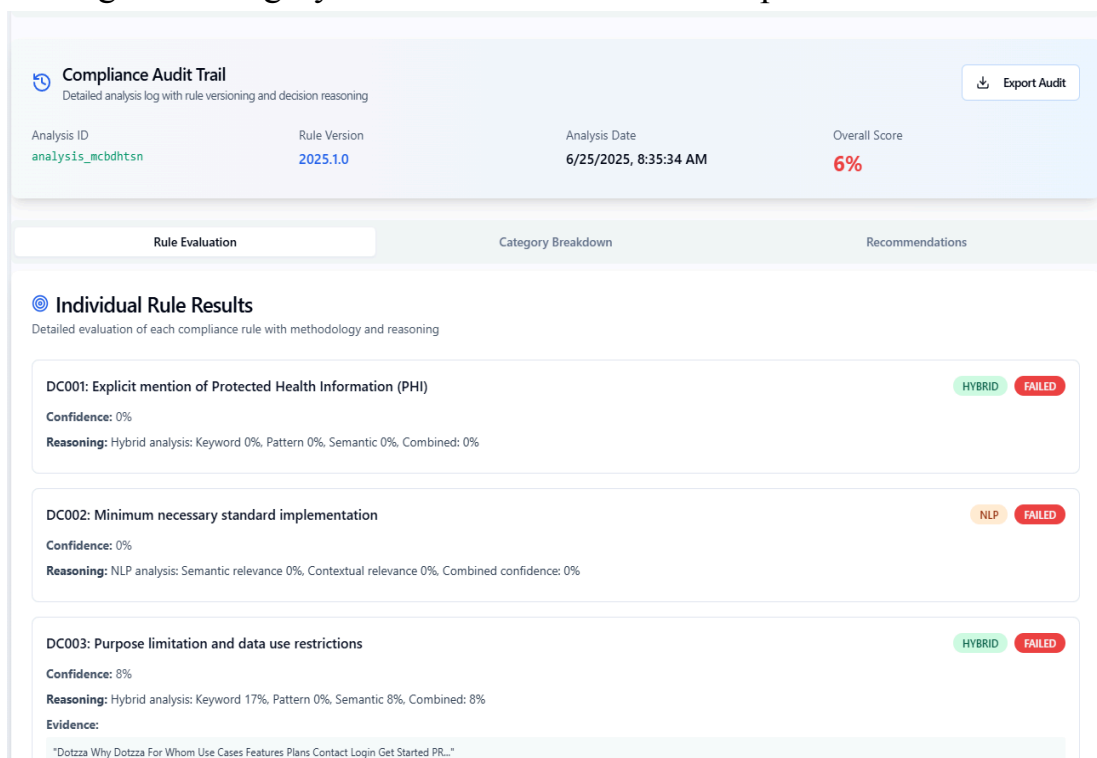


Fig A.4 : Audit Trail - Rule Evaluation for Dotzza healthcare platform

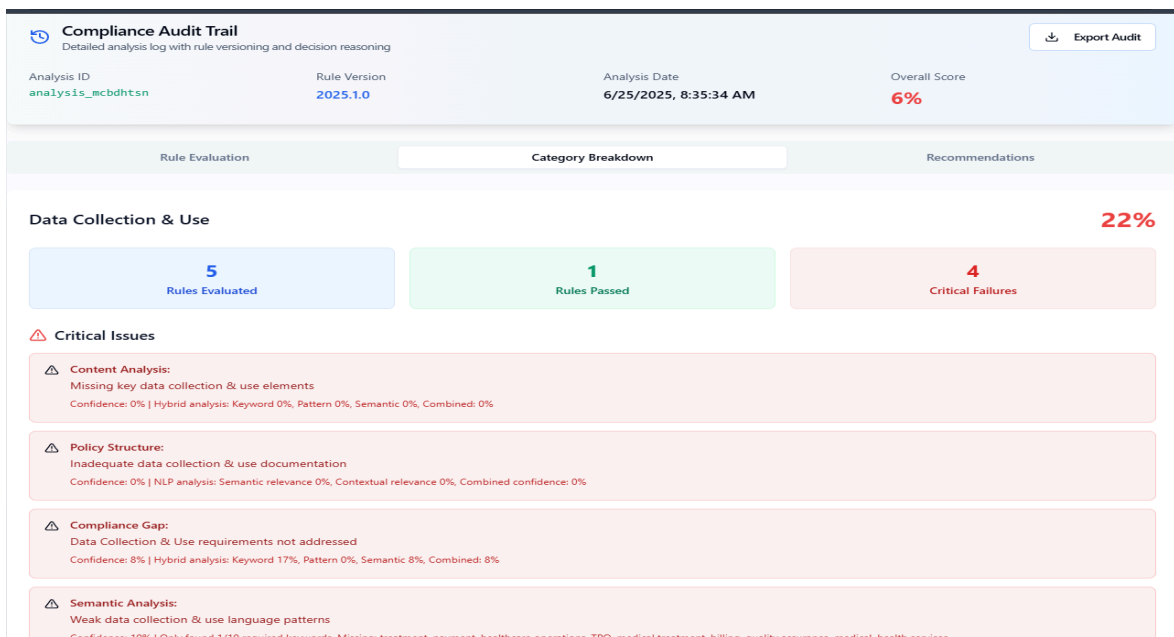


Fig A.5 : Audit Trail - Category-wise analysis (6 over 38 rules) for Dotzza healthcare platform

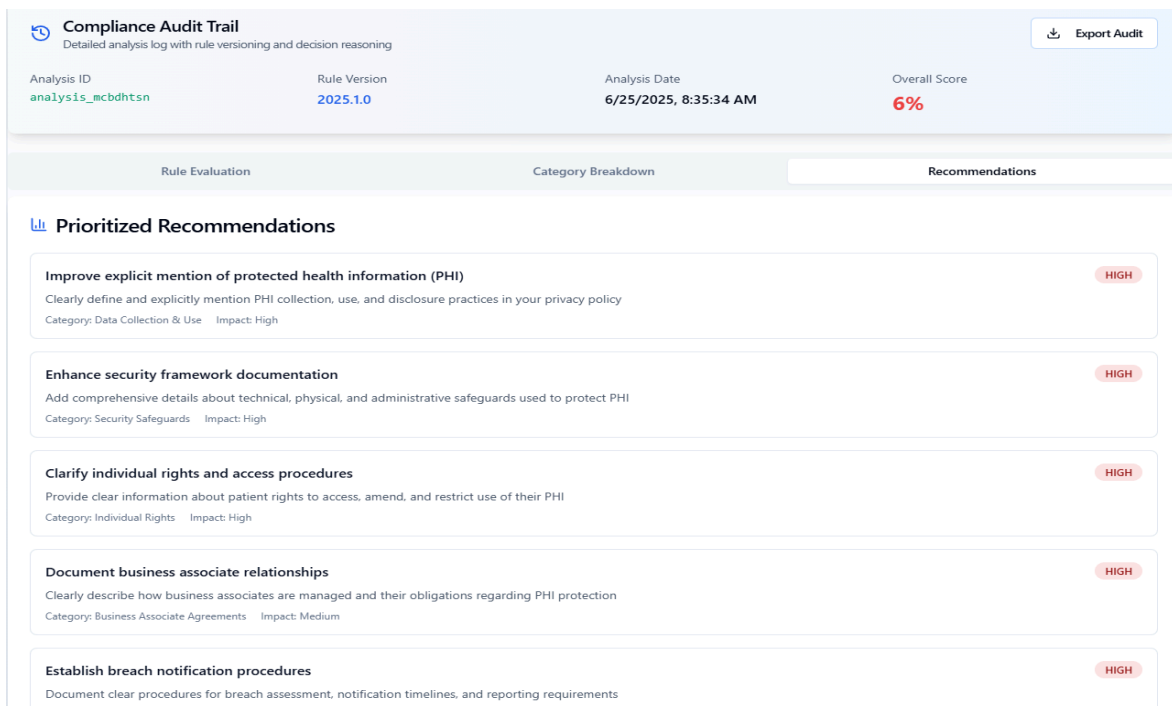


Fig A.6 : Audit Trail - Recommendations for the website for Dotzza healthcare platform

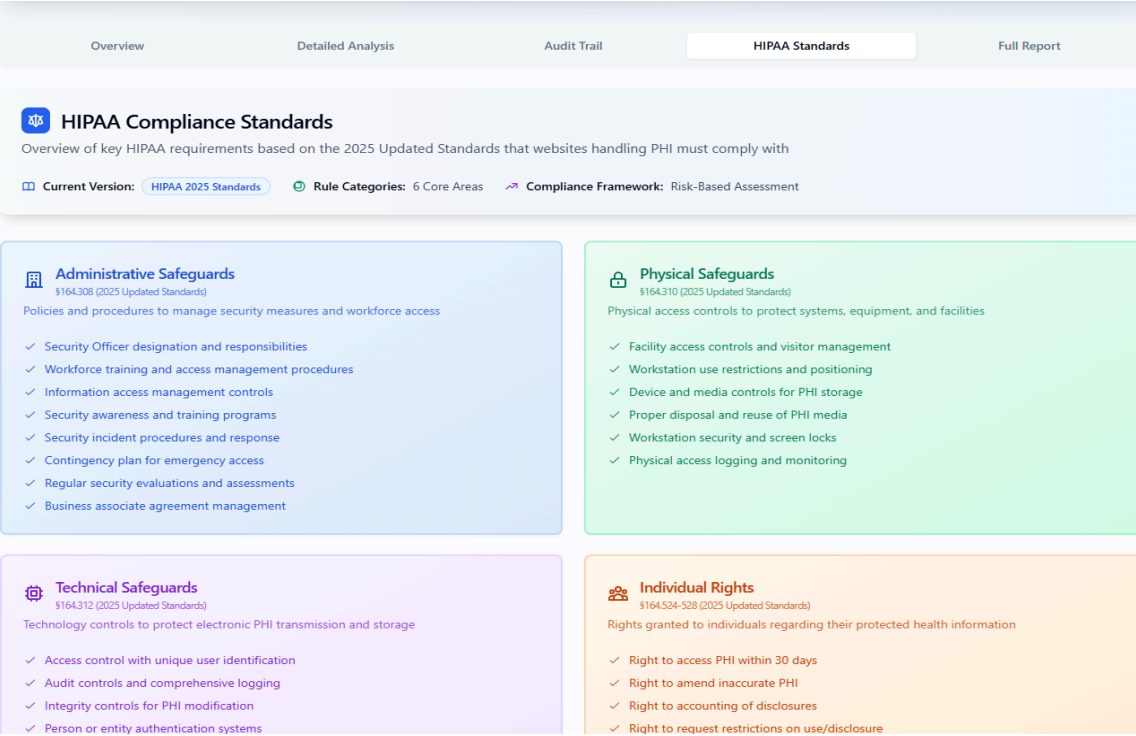


Fig A.7 : Displays recent HIPAA Standard rules set for analysis for Dotzza healthcare platform

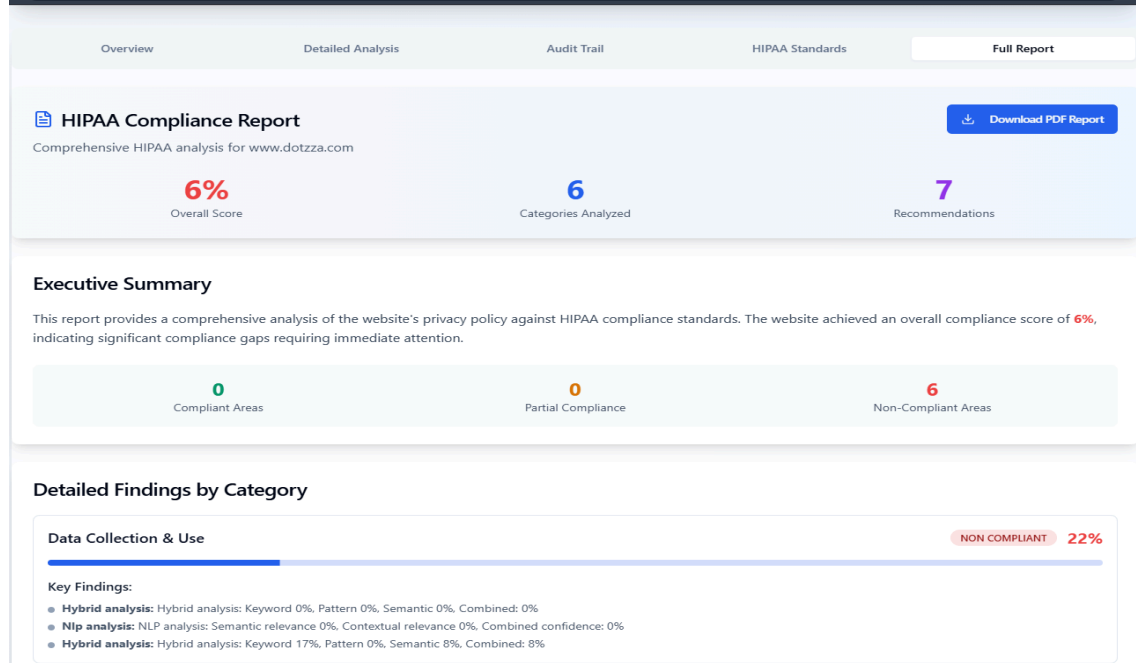


Fig A.8 : Full report of the HIPAA compliance score analysis for Dotzza healthcare platform

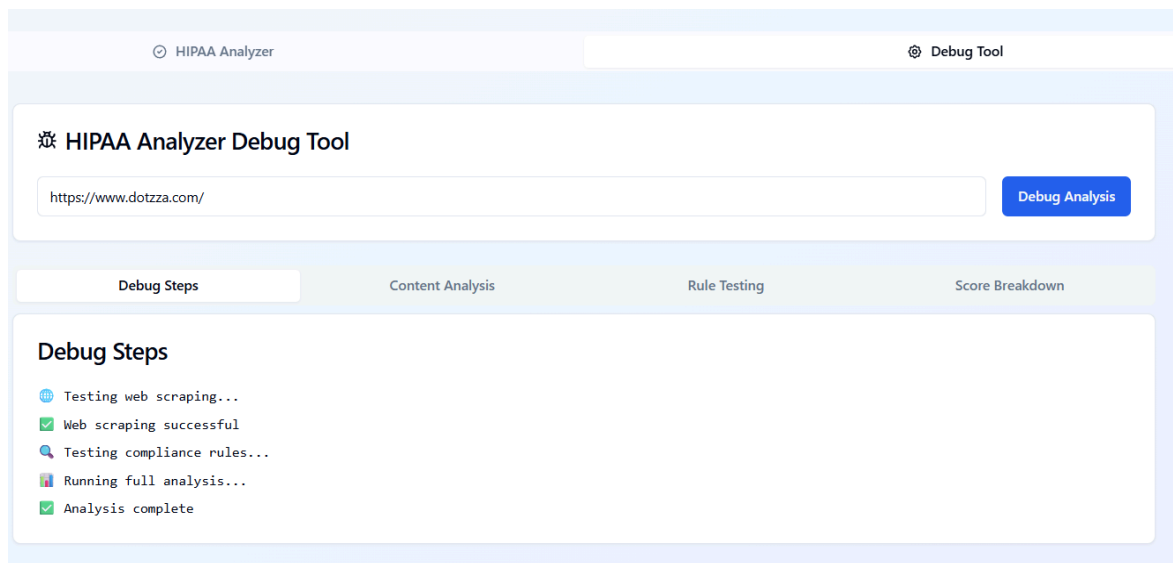


Fig A.9 : HIPAA Analyser Debug Tool feature displaying Debugging steps for Dotzza healthcare platform

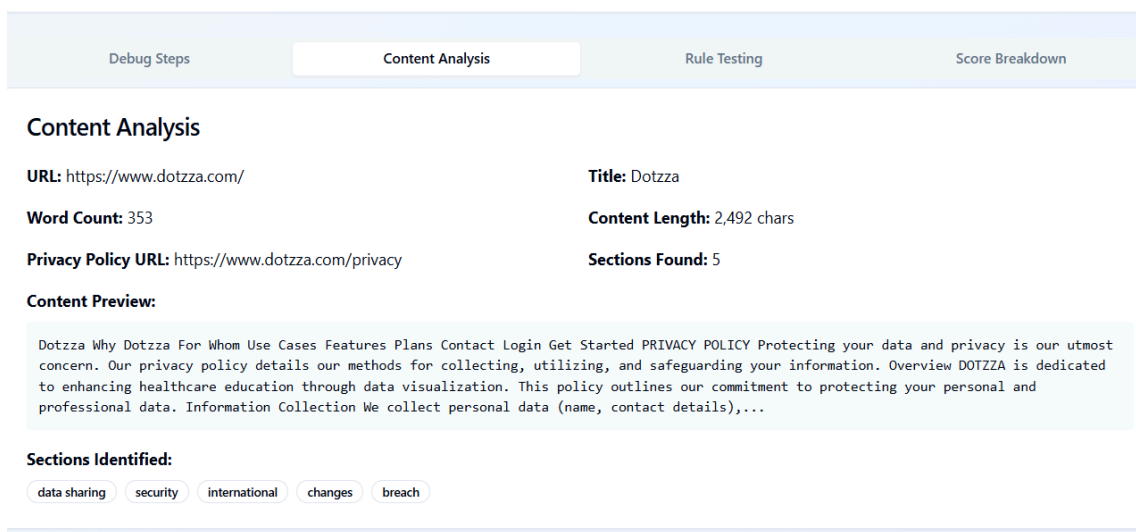


Fig A.10 : HIPAA Debug Analyzer displaying Content analysis for Dotzza healthcare platform

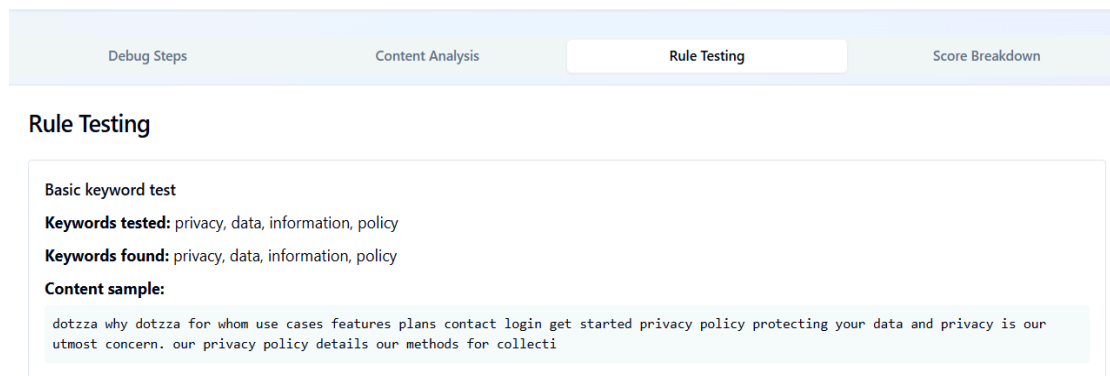


Fig A.11 : HIPAA Debug Analyzer displaying the sample of rule testing process for Dotzza healthcare platform

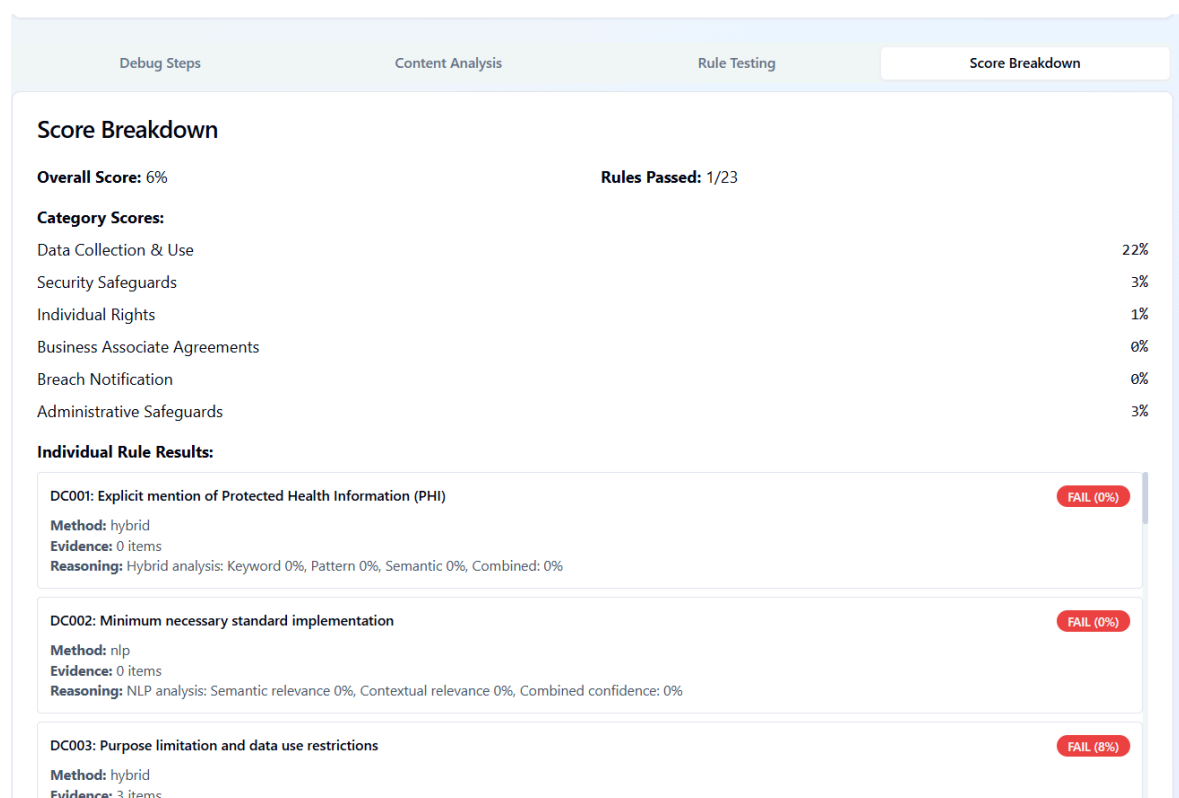


Fig A.12 : HIPAA Debug Analyzer displaying Category score measured and also the individual rule result(Confidence). for Dotzza healthcare platform

COMPLIANCE ANALYSIS REPORT

6/24/2025

COMPLIANCE OVERVIEW

' **Compliant Areas: 0**
& **Partial Compliance: 0**
' **Non-Compliant Areas: 6**

DETAILED CATEGORY ANALYSIS

DATA COLLECTION & USE

Score: 22% - NON-COMPLIANT

Key Findings:

- HYBRID: Hybrid analysis: Keyword 0%, Pattern 0%, Semantic 0%, Combined: 0%
- NLP: NLP analysis: Semantic relevance 0%, Contextual relevance 0%, Combined confidence: 0%

SECURITY SAFEGUARDS

Score: 3% - NON-COMPLIANT

Key Findings:

- HYBRID: Hybrid analysis: Keyword 25%, Pattern 0%, Semantic 25%, Combined: 18%
- KEYWORD: Only found 0/5 required keywords. Missing: physical safeguards, facility access, workstation security, device controls, media controls

COMPLIANCE ANALYSIS REPORT

6/24/2025

INDIVIDUAL RIGHTS

Score: 1% - NON-COMPLIANT

Key Findings:

- HYBRID: Hybrid analysis: Keyword 22%, Pattern 0%, Semantic 0%, Combined: 7%
- HYBRID: Hybrid analysis: Keyword 0%, Pattern 0%, Semantic 0%, Combined: 0%

BUSINESS ASSOCIATE AGREEMENTS

Score: 0% - NON-COMPLIANT

Key Findings:

- HYBRID: Hybrid analysis: Keyword 0%, Pattern 0%, Semantic 0%, Combined: 0%
- KEYWORD: Only found 0/5 required keywords. Missing: BAA, business associate agreement, written agreement, safeguard obligations, return PHI

BREACH NOTIFICATION

Score: 0% - NON-COMPLIANT

Key Findings:

- HYBRID: Hybrid analysis: Keyword 0%, Pattern 0%, Semantic 0%, Combined: 0%
- REGEX: Only found 0/3 required patterns

ADMINISTRATIVE SAFEGUARDS

Score: 3% - NON-COMPLIANT

Key Findings:

- REGEX: Only found 1/5 required patterns
- KEYWORD: Only found 0/6 required keywords. Missing: complaint, grievance, privacy concerns, file complaint, report violation, privacy complaint

PRIORITY RECOMMENDATIONS

- 1

Improve explicit mention of protected health information (PHI) (HIGH)

Clearly define and explicitly mention PHI collection, use, and disclosure practices in your privacy policy

Category: Data Collection & Use | Impact: High
- 2

Enhance security framework documentation (HIGH)

Add comprehensive details about technical, physical, and administrative safeguards used to protect PHI

Category: Security Safeguards | Impact: High
- 3

Clarify individual rights and access procedures (HIGH)

Provide clear information about patient rights to access, amend, and restrict use of their PHI

Category: Individual Rights | Impact: High
- 4

Document business associate relationships (HIGH)

Clearly describe how business associates are managed and their obligations regarding PHI protection

Category: Business Associate Agreements | Impact: Medium
- 5

Establish breach notification procedures (HIGH)

Document clear procedures for breach assessment, notification timelines, and reporting requirements

Category: Breach Notification | Impact: High
- 6

Designate privacy officer and complaint procedures (HIGH)

Clearly identify privacy officer contact information and establish formal complaint procedures

Category: Administrative Safeguards | Impact: Medium

- 7

Improve overall policy clarity and completeness (HIGH)

Many HIPAA requirements are unclear or missing. Consider comprehensive policy review and update

Category: General | Impact: High

TECHNICAL ANALYSIS DETAILS

Analysis Methodology:

- Multi-layered content analysis using keyword matching, pattern recognition, and semantic analysis
- Compliance scoring based on industry standards and regulatory requirements
- Risk assessment and prioritized recommendations for improvement

Report Metadata:

Analysis Date: 6/24/2025, 5:25:53 PM
Report Version: 1.0
Analysis ID: N/A

Fig A.13 : Exported PDF snapshot of full report analysis for Dotzza healthcare platform

APPENDIX –II: Only sample code/ Function call/ Abstract code of the project.

1. page.tsx

```
import { HIPAAAnalyzer } from "@components/hipaa-analyzer"

import { DebugAnalyzer } from "@components/debug-analyzer"

import { Tabs, TabsContent, TabsList, TabsTrigger } from
"@components/ui/tabs"

import { Badge } from "@components/ui/badge"

export default function Home() {

  return (

    <div className="min-h-screen bg-gradient-to-br from-slate-50
via-blue-50 to-indigo-50">

      {/* Hero Section */}

      <div className="relative overflow-hidden">

        <div className="absolute inset-0 bg-grid-slate-100
[mask-image:linear-gradient(0deg,white,rgba(255,255,255,0.6))]
-z-10" />

        <div className="container mx-auto px-4 py-16">

          <div className="text-center mb-12">

            <div className="inline-flex items-center gap-3
mb-6">

              <div className="w-12 h-12 bg-blue-600 rounded-xl
flex items-center justify-center">

                <svg className="w-7 h-7 text-white" fill="none"
stroke="currentColor" viewBox="0 0 24 24">

                  <path

                    strokeLinecap="round"

                    strokeLinejoin="round"
```

2. Compliance_analyser.ts

```
3. import type { ScrapedContent } from "../web-scraper"
4. import { CATEGORY_WEIGHTS, COMPLIANCE_RULES } from
   "../compliance-rules"
5. import { NLPAnalyzer } from "../nlp-analyzer"
6.
7. export interface RuleResult {
8.     ruleId: string
9.     description: string
10.    passed: boolean
11.    confidence: number
12.    evidence: string[]
13.    reasoning: string
14.    method: "keyword" | "regex" | "hybrid" | "nlp" | "legal"
15.    category: string
16.    hipaaSection?: string
17. }
18.
19. export interface AnalysisResult {
20.    overallScore: number
21.    categoryScores: Record<string, number>
22.    categoryWeights: Record<string, number>
23.    ruleResults: RuleResult[]
24.    passedRules: number
25.    totalRules: number
26.    metadata: {
27.        wordCount: number
28.        sectionsFound: number
```

3. hipaa_analyzer.tsx

```
"use client"

import { useState } from "react"

import { Button } from "@/components/ui/button"

import { Input } from "@/components/ui/input"

import { Card, CardContent, CardDescription, CardHeader,
CardTitle } from "@/components/ui/card"

import { Progress } from "@/components/ui/progress"

import { Badge } from "@/components/ui/badge"

import { Tabs, TabsContent, TabsList, TabsTrigger } from
"@/components/ui/tabs"

import { Alert, AlertDescription } from "@/components/ui/alert"

import { WebScraperService } from "@/lib/web-scraper"

import { ComplianceAnalyzer } from "@/lib/compliance-analyzer"

import { ReportGenerator } from "@/lib/report-generator"

import { VisualReports } from "@/components/visual-reports"

import { AuditTrail } from "@/components/audit-trail"

import { HIPAAStandards } from "@/components/hipaa-standards"

import { FullReport } from "@/components/full-report"

import type { AnalysisResult } from "@/types/compliance"

export function HIPAAAnalyzer() {

  const [url, setUrl] = useState("")

  const [isAnalyzing, setIsAnalyzing] = useState(false)

  const [analysisResult, setAnalysisResult] =
useState<AnalysisResult | null>(null)

  const [error, setError] = useState<string | null>(null)

  const [progress, setProgress] = useState(0)

  const [currentStep, setCurrentStep] = useState("")
```

REFERENCES

Journal References:

1. Rindfleisch, T. C. (1997), “Privacy, information technology, and health care”, *Communications of the ACM*, 40(8), 92–100.
2. Appari, A., & Johnson, M. E. (2010), “Information security and privacy in healthcare: current state of research”, *International Journal of Internet and Enterprise Management*, 6(4), 279–314.
3. Kruse, C. S., Smith, B., Vanderlinden, H., & Nealand, A. (2017), “Security techniques for the electronic health records”, *Journal of Medical Systems*, 41(8), 127.
4. Fernandez-Aleman, J. L., et al. (2013), “Security and privacy in electronic health records: A systematic literature review”, *Journal of Biomedical Informatics*, 46(3), 541–562.
5. Rodrigues, J. J., et al. (2013), “Analysis of the security and privacy requirements of cloud-based electronic health records systems”, *Journal of Medical Internet Research*, 15(8), e186.
6. Yasnoff, W. A., Sweeney, L., Shortliffe, E. H. (2001), “Putting health IT on the right track”, *Health Affairs*, 20(5), 63–73.
7. Ben-Assuli, O. (2015), “Electronic health records, adoption, quality of care, legal and privacy issues”, *Health Policy*, 119(3), 287–297.
8. Wang, H., & Wang, X. (2008), “Privacy protection in electronic medical records”, *IEEE Access*, 8, 1554–1564.

9. Health Insurance Portability and Accountability Act of 1996 (HIPAA). Centers for Disease Control and Prevention, Public Health Law. 2024. URL:https://www.cdc.gov/phlp/php/resources/health-insurance-portability-and-accountability-act-of-1996-hipaa.html?CDC_AAref_Val=https://www.cdc.gov/phlp/publications/topic/hipaa.html
10. Yuxin Chen et al. (2025), “Using LLMs for Automated Privacy Policy Analysis: Prompt Engineering, Fine-Tuning and Explainability”, arXiv preprint arXiv:2503.16516v1. (Note: As a preprint, this paper does not have a traditional journal volume or page numbers).
11. Hao Cui et al. (2025), “PoliGraph: Automated Privacy Policy Analysis using Knowledge Graphs”, arXiv preprint arXiv:2210.06746v3. (Note: This is a preprint and lacks traditional journal, volume, or page numbers).
12. Jeffrey A. Marron (2024), “Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide”, NIST Special Publication 800-66r2.
13. Ateya Megahed Ibrahim et al. (2024), “Balancing confidentiality and care coordination: challenges in patient privacy”, BMC Nursing, 23, Article 564. (Note: This journal uses an article number instead of an issue number).
14. Bilash Saha et al. (2023), “HIPAAChecker: The Comprehensive Solution for HIPAA Compliance in Android mHealth Apps”, arXiv preprint arXiv:2306.06448v1.
15. Raza Nowrozy et al. (2023), “Towards a Universal Privacy Model for Electronic Health Record Systems: An Ontology and Machine Learning Approach”, Informatics, 10(3), 60.
16. Md Al Amin et al. (2023), “Healthcare Policy Compliance: A Blockchain Smart Contract-Based Approach”, arXiv preprint arXiv:2312.10214v1.

- 17.Chenhao Tang et al. (2023), “PolicyGPT: Automated Analysis of Privacy Policies with Large Language Models”, arXiv preprint arXiv:2309.10238v1.
- 18.Michael Adelusola (2021), “Healthcare Compliance in the Digital Era: Leveraging Automated Tools for Accuracy”, ResearchGate, Article, June 2021. (Note: This is an unpublished article on ResearchGate and does not have journal/volume details).
- 19.Nadia Rehman (2021), “Automating Privileged Access Controls to Meet HIPAA and GxP Standards in Healthcare”, ResearchGate, Research, December 2021, DOI: 10.13140/RG.2.2.29091.26403.
- 20.Scholas Mbonihankuye et al. (2019), “Healthcare Data Security Technology: HIPAA Compliance”, Wireless Communications and Mobile Computing, Volume 2019, Article ID 1927495, 1-7.
- 21.Donna Vanderpool (2019), “HIPAA COMPLIANCE: A Common Sense Approach”, Innovations in Clinical Neuroscience, 16(1–2), 38-41.
- 22.Hamza Harkous et al. (2018), “Polisis: Automated Analysis and Presentation of Privacy Policies Using Deep Learning”, arXiv preprint arXiv:1802.02561v2. (Note: This was also presented at the 28th USENIX Security Symposium).
- 23.Deepak Garg et al. (2011), “A Logical Method for Policy Enforcement over Evolving Audit Logs”, Technical Report CMU-CyLab-11-002 and arXiv preprint arXiv:1102.2521v3.
- 24.Hemang Subramanian et al. (2024), “Patient Health Record Protection Beyond the Health Insurance Portability and Accountability Act: Mixed Methods Study”, Journal of Medical Internet Research, 26, e59674.

Web References:

1. Python for Data Science - Course for Beginners (Learn Python, Pandas, NumPy, Matplotlib) – <https://www.youtube.com/watch?v=LHBE6Q9Xlzl>
2. U.S. Department of Health & Human Services – HIPAA Overview – <https://www.hhs.gov/hipaa>
3. SecureFrame – Compliance Automation Platform – <https://www.secureframe.com>
4. Compliancy Group – HIPAA Compliance Made Easy – <https://www.compliancy-group.com>
5. Vanta – Continuous Compliance Monitoring – <https://www.vanta.com>
6. Health and Human Services (HHS) from USA - Compliance score generator tool - <https://www.hhs.gov/>
7. HIPAA One – Enterprise HIPAA Audit Software – <https://www.hipaaone.com>
8. Accountable HQ – Lightweight HIPAA Dashboard – <https://www.accountablehq.com>
9. Tailwind CSS – Responsive Design Documentation – <https://tailwindcss.com/docs>
10. React.js – Official Docs for Frontend Development – <https://reactjs.org>
11. MDN Web Docs – HTML, CSS, and JavaScript Standards – <https://developer.mozilla.org>



SRI RAMACHANDRA

INSTITUTE OF HIGHER EDUCATION AND RESEARCH

(Category - I Deemed to be University) Porur, Chennai

SRI RAMACHANDRA FACULTY OF ENGINEERING AND TECHNOLOGY

EXTERNAL INTERNSHIP WORK LOG SHEET – CYB23IN201

STUDENT NAME : ADVAITA SURESH

UNIQUE ID: E0223009

PROJECT TITLE : WEB DEVELOPMENT & HIPAA

COMPANY NAME: SeeDataMD

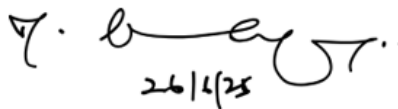
COMPLIANCE CHECKLIST TOOL

DATE	BRIEF DESCRIPTION OF THE DAY'S ACTIVITY
May 1	Intern induction, reviewed project documentation
May 2	Notion tool introduction, White paper analysis was done
May 3	More notion pages created and practiced
May 4	Critical Appraisal of deck & whitepaper [Phase-1 pre-login] was completed
May 5	1. Walkthrough of Dotzza platform 2. Critical Appraisal of Dotzza (Pre-Login) Phase - 1 was updated as in expected format.
May 6	1. Drafted and submitted the Weekly report [1st week]. 2. Visited website to get comfortable with it for bug testing.
May 7	Started the sample project assigned
May 8	1. Final submission of critical appraisal [Phase-1] & Notion tool practice. 2. Working on sample project
May 9	Sample project work has been started.
May 10	Sample project first look was completed and submitted.

May 12	Working on sample project for second look.
May 13	Visited the website to get used to it.
May 14	1. Completed the Sample project assigned. 2. Submitted the 2nd week report.
May 15	Identifying the bugs in the website using given login access and reported the same in the Work Issue Tracker.
May 16	Formed teamspaces and continued on the bug testing
May 17	Weekly Report for third week is submitted
May 19	Looked for HTML/CSS based bugs in the website. This included the alignment bugs in mobile screen view and desktop view. Reported the same in Work Issue Tracker.
May 20	1. Looked for any issue in responsiveness of the website. 2. Worked with the team spaces , checked for issues. Reported the same in Work Issue Tracker.
May 21	1. Continued reviewing DOTZZA's post-login features by testing more modules and user cases. Updated the report with detailed notes on usability issues. 2. Received the bugs that were currently present in the website. Analyzed the same to solve it later.
May 22	1. Attended an introductory meeting with Mr. Rajesh, the Technical Lead. 2. Gained access to the company's GitHub repository, installed necessary tools (e.g., JavaScript), and cloned the project from GitHub.
May 23	1. Understood the basic code structure, 2. Learned URL navigation 3. Explored how to run and review the project in browsers.
May 24	1. I was assigned three bug to debug , I analysed the same. The bugs are : Image sizing issue on the Healthcare-Education page, Sizing issue on the FAQ section, Constant form sizing issue. 2. Found solutions to the first two bugs . 3. Weekly report for this week was submitted.
May 26	1. Thoroughly analyzed all assigned bugs and identified effective solutions for each. 2. Learned about nextjs to work on the project.
May 27	1. I tried debugging the code for Contact form sizing in dotzza.com2/contactus URL page. 2. Faced difficulty in understanding the layouts, pages, routing . So I studied about those concepts to debug efficiently.
May 28	1. Explored various aspects of the code by modifying color schemes, font styles, pixel dimensions, and other configuration options to gain a deeper understanding of the underlying

	structure and functionality. 2. Studied the architecture and key functionalities of Next.js to build a foundational understanding of the framework.
May 29	1. Studied the data fetching , upgrading and routing f- next.js. 2. Found the issue for the bugs and found solutions for it also. Yet to be implemented in the code.
May 30	1. Implementation of solution to image sizing bug in dotzza.com2/healthcare-education URL page. 2. Implementation of solution to FAQ's sizing bug in dotzza.com2/healthcare-education URL page. 3. Implementation of solution to Contact form sizing bug in dotzza.com2/contactus URL page.
May 31	1. Faced issues in implementation of solutions to those bugs. So studied more about the navigation , architecture of code to solve those issues. 2. Weekly report for this week was submitted.
June 2	1. Added sample text to government page URL in website to test and understand the functionality. 2. The alignment issue in FAQ page is resolved. Yet to be finalised.
June 3	While debugging alignments in healthcare-education page ,faced many errors . Trying to identify and resolve them.
June 4	Gained insights into Seedatamd Group's vision and core competencies.
June 5	The error that occurred while debugging was image sizing in healthcare-education part is resolved.
June 6	1. All the bugs are resolved. 2. Started Seedatamd makeover page.
June 7	1. Building first look for Seedatamd makeover page. 2. Weekly report for week 6 is submitted.
June 9	HIPAA Compliance Checklist Tool - Created the framework for the project to get started with the coding.
June 10	HIPAA Compliance Checklist Tool - Created project folder structure and started basic HTML, CSS, javascript coding to add base to the frontend.
June 11	1. Documentation of Frontend work was submitted in the Work Issue Tracker. 2. Seedatamd makeover page - searching websites like 21stdev, lovable.dev and more for creating framework of the site.
June 12	1. Building first look of the Seedatamd makeover page using v0.dev 2. User stories of cyber project (HIPAA Compliance Checklist Tool) is planned.
June 13	1. Basic frontend (HTML,TailwindCSS, JS) for the cyber project is done. 2. First look Seedatamd makeover page is completed and submitted.

June 14	1. Working on functionalities of the cyber project. 2. Weekly report for week 7 is submitted.
June 17	Discussed with College mentor regarding cyber project. Got ideas and suggestions to update the project.
June 16	1. Created basic frontend application which contains a checklist of all the standard HIPAA privacy & policies , and lets the admin to choose them , computes the compliance score and generates a HIPAA report as a pdf. This pdf contains the areas of partial and non-compliance and recommendations to overcome them for the dotzza website to make it compliant. 2. Adding pictures , contents for seedatamd makeover
June 18	1. Updating the HIPAA compliance framework as suggested. 2. Matching contents & pictures for seedatamd makeover page.
June 19	1. The HIPAA Compliance cyber project is completed, but it has some errors. The compliance score changes everytime it is being analysed. So looking for debugging that error. 2. Seedatamd makeover page is submitted.
June 20	Updating cyber project, debugging the error by integrating basic NLP , hybrid methods to compute compliance check.
June 21	1. HIPAA Compliance CheckList Tool project is completed and submitted. 2. Weekly report for this week is also submitted.


26/6/25

EXTERNAL GUIDE SIGN & COMPANY SEAL

SEEDATAMD PRIVATE LIMITED
188/3, GUPTHA NAGAR,
ANGAMMAL COLONY,
NEAR MANGAI CLINIC
SALEM-636 009. TAMILNADU,

OFFER LETTER



INTERNSHIP OFFER LETTER

Date: 30 April 2025

To:

Ms. Advaita Suresh,
Student, Department of Cybersecurity & IoT,
Sri Ramachandra Institute of Higher Education and Research, Chennai

Subject: Internship Offer Letter – Advaita Suresh

Dear Advaita Suresh,

We are delighted to offer you the position of **Cybersecurity and Web Development** in **SeeDataMD Private Limited**, as part of your academic requirements at Sri Ramachandra Institute of Higher Education and Research.

Internship Details:

- Internship Role: Cybersecurity & Web Development Intern
- Start Date: May 1, 2025 to July 2, 2025
- Mode of Internship: Remote
- Working Days/Hours: Monday to Friday (8 hours per day)

During your internship, you will have the opportunity to work on real-world Web, AI and Machine learning projects under the guidance of our experienced team. We believe this experience will greatly benefit your learning and professional growth.

Welcome aboard!

Best Regards,

For SEEDATAMD PRIVATE LIMITED

M. Chokkalingam, DIRECTOR

CEO, SeeDataMD Private Limited,

Salem

 seedatamd@gmail.com

 188/3, Guptha Nagar, Angammal Colony,
Near Mangai Clinic,
Salem - 636 003, Tamilnadu

 0427-3558602
96294 28340

CERTIFICATE OF COMPLETION



DATE: 26.06.2025

CERTIFICATE OF INTERNSHIP COMPLETION

This is to certify that **Advaita Suresh**, from Sri Ramachandra Faculty of Engineering And Technology, Chennai, pursuing **B.Tech (Cybersecurity & IoT)**, has successfully completed an internship at **SeeDataMD Pvt. Ltd** from **2nd May 2025 to 25th June 2025** in a **remote (online)** capacity.

During this period, the intern was actively involved in:

- Critical appraisal of product pitch decks and whitepapers
- Hands-on experience with productivity tools Notion for documentation
- Cybersecurity research and compliance planning
- Functional and UI/UX issue tracking of web and mobile apps
- Website content restructuring and UI optimization for seedatamd.com

The intern demonstrated professionalism, discipline, and technical engagement throughout the internship. Their performance was periodically assessed, and weekly mentorship was provided by **Dr. Chokkalingam**, Founder & Director, SeedataMD.

We appreciate their contribution and wish them all the best in their future endeavors.

For SEEDATAMD PRIVATE LIMITED


DIRECTOR

(Dr.M.Chokkalingam)

Founder & CEO, SeeDataMD


seedatamd@gmail.com


188/3, Guptha Nagar, Angammal Colony,
Near Mangai Clinic,
Salem - 636 003, Tamilnadu


0427-3558602
96294 28340



SRI RAMACHANDRA

INSTITUTE OF HIGHER EDUCATION AND RESEARCH

(Category - I Deemed to be University) Porur, Chennai

SRI RAMACHANDRA FACULTY OF ENGINEERING AND TECHNOLOGY

EXTERNAL INTERNSHIP – ATTENDANCE FORM

CYB23IN201

STUDENT NAME: ADVAITA SURESH

UNIQUE ID: E0223009

YEAR OF STUDY: 2023-2027

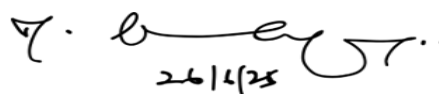
**DEGREE & BRANCH: BTECH COMPUTER SCIENCE ENGINEERING - CYBER
SECURITY & IOT**

STARTING DATE: 1ST MAY, 2025

ENDING DATE: 2ND JULY, 2025

NO OF HOURS WORKED: 8 hours / day

REMARKS: I completed a two-month remote internship at Seedatamd Private Limited from May 1, 2025 to July 2, 2025 in the role of Cybersecurity & Web Development Intern. During this internship, I had the opportunity to work on real-time projects that focused on both web development and cybersecurity domains. I was exposed to practical aspects of web security, HIPAA compliance analysis, and machine learning integration for security tools. This internship enhanced both my technical and analytical skills, and gave me valuable exposure to how cybersecurity principles are applied in healthcare-oriented tech platforms.


26/4/25

EXTERNAL GUIDE SIGN & COMPANY SEAL

(SIGN WITH DATE)

SEEDATAMD PRIVATE LIMITED
188/3, GUPTHA NAGAR,
ANGAMMAL COLONY,
NEAR MANGAI CLINIC
SALEM-636 009. TAMILNADU.